

|                                                                                                                                                   |                                                                                                                                                                                                                                                                                                                                              |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            |                                                                               |                                                                                                                  |                                                         |                                 |                                       |  |
|---------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------|-------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------|---------------------------------|---------------------------------------|--|
| <b>REQUEST FOR QUOTATIONS</b><br>(THIS IS NOT AN ORDER)                                                                                           |                                                                                                                                                                                                                                                                                                                                              |                             | THIS RFQ <input checked="" type="checkbox"/> IS <input type="checkbox"/> IS NOT A SMALL BUSINESS SET-ASIDE.                                                                                                                                                                                                                                                                                                                                                                                                                      |                                                            |                                                                               | PAGE 1 OF 72 PAGES                                                                                               |                                                         |                                 |                                       |  |
| 1. REQUEST NO.<br>75D301-26-Q-00146                                                                                                               |                                                                                                                                                                                                                                                                                                                                              | 2. DATE ISSUED<br>8/17/2026 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 3. REQUISITION/PURCHASE REQUEST NO.<br>000HCRDB-2026-00146 |                                                                               | 4. CERT. FOR NAT. DEF. UNDER BDSA REG. 2 AND/OR DMS REG. 1                                                       |                                                         | RATING                          |                                       |  |
| 5a. ISSUED BY<br>Centers for Disease Control and Prevention<br>Chamblee Campus Building 108, MS S108-4<br>4770 Buford Hwy<br>Atlanta GA 303413717 |                                                                                                                                                                                                                                                                                                                                              |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            |                                                                               | 6. DELIVERY BY (Date)                                                                                            |                                                         |                                 |                                       |  |
| 5b. FOR INFORMATION CALL (No collect calls)                                                                                                       |                                                                                                                                                                                                                                                                                                                                              |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            |                                                                               | 7. DELIVERY<br><input checked="" type="checkbox"/> FOB DESTINATION <input type="checkbox"/> OTHER (See Schedule) |                                                         |                                 |                                       |  |
| NAME<br>H. Dale Bish                                                                                                                              |                                                                                                                                                                                                                                                                                                                                              |                             | TELEPHONE NUMBER<br>AREA CODE (404) NUMBER 498-1312                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |                                                            |                                                                               |                                                                                                                  |                                                         |                                 |                                       |  |
| 8. TO:                                                                                                                                            |                                                                                                                                                                                                                                                                                                                                              |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            |                                                                               | 9. DESTINATION                                                                                                   |                                                         |                                 |                                       |  |
| a. NAME                                                                                                                                           |                                                                                                                                                                                                                                                                                                                                              |                             | b. COMPANY                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |                                                            |                                                                               | a. NAME OF CONSIGNEE                                                                                             |                                                         |                                 |                                       |  |
| c. STREET ADDRESS                                                                                                                                 |                                                                                                                                                                                                                                                                                                                                              |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            |                                                                               | b. STREET ADDRESS                                                                                                |                                                         |                                 |                                       |  |
|                                                                                                                                                   |                                                                                                                                                                                                                                                                                                                                              |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            |                                                                               | c. CITY                                                                                                          |                                                         |                                 |                                       |  |
| d. CITY                                                                                                                                           |                                                                                                                                                                                                                                                                                                                                              |                             | e. STATE                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |                                                            | f. ZIP CODE                                                                   |                                                                                                                  | d. STATE                                                |                                 | e. ZIP CODE                           |  |
| 10. PLEASE FURNISH QUOTATIONS TO THE ISSUING OFFICE IN BLOCK 5a ON OR BEFORE CLOSE OF BUSINESS (Date)<br>09/08/2026 10 AM ET                      |                                                                                                                                                                                                                                                                                                                                              |                             | IMPORTANT: This is a request for information, and quotations furnished are not offers. If you are unable to quote, please so indicate on this form and return it. This request does not commit the Government to pay any costs incurred in the preparation of the submission of this quotation or to contract for supplies or services. Supplies are of domestic origin unless otherwise indicated by quoter. Any representations and/or certifications attached to this Request for Quotations must be completed by the quoter. |                                                            |                                                                               |                                                                                                                  |                                                         |                                 |                                       |  |
| 11. SCHEDULE (Include applicable Federal, State and local taxes)                                                                                  |                                                                                                                                                                                                                                                                                                                                              |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            |                                                                               |                                                                                                                  |                                                         |                                 |                                       |  |
| ITEM NO.<br>(a)                                                                                                                                   | SUPPLIES/SERVICES<br>(b)                                                                                                                                                                                                                                                                                                                     |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            | QUANTITY<br>(c)                                                               | UNIT<br>(d)                                                                                                      | UNIT PRICE<br>(e)                                       | AMOUNT<br>(f)                   |                                       |  |
|                                                                                                                                                   | <b>Project Title:</b><br><b>Modernized Application for Consumer and Healthcare Provider VAERS Reporting</b><br><br>SCHEDULE: See Price Breakdown Worksheet (Volume II, Tab 1) per Amendment 0001 Q&A 73<br><br><b>Questions, Quotes, and All Communication is to be with H. Dale Bish at <a href="mailto:uwo8@cdc.gov">uwo8@cdc.gov</a>.</b> |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            |                                                                               |                                                                                                                  |                                                         |                                 |                                       |  |
| 12. DISCOUNT FOR PROMPT PAYMENT                                                                                                                   |                                                                                                                                                                                                                                                                                                                                              |                             | a. 10 CALENDAR DAYS %                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |                                                            | b. 20 CALENDAR DAYS %                                                         |                                                                                                                  | c. 30 CALENDAR DAYS %                                   |                                 | d. CALENDAR DAYS<br>NUMBER PERCENTAGE |  |
| NOTE: Additional provisions and representations <input type="checkbox"/> are <input type="checkbox"/> are not attached.                           |                                                                                                                                                                                                                                                                                                                                              |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            |                                                                               |                                                                                                                  |                                                         |                                 |                                       |  |
| 13. NAME AND ADDRESS OF QUOTER                                                                                                                    |                                                                                                                                                                                                                                                                                                                                              |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            | 14. SIGNATURE OF PERSON AUTHORIZED TO SIGN QUOTATION                          |                                                                                                                  |                                                         | 15. DATE OF QUOTATION           |                                       |  |
| a. NAME OF QUOTER<br>Frasier Digital, LLC (UEI PY8MJ4JPHJ45 · CAGE 213L8 · TIN 41-3497002)                                                        |                                                                                                                                                                                                                                                                                                                                              |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            |                                                                               |                                                                                                                  |                                                         |                                 |                                       |  |
| b. STREET ADDRESS<br>20915 Mystic Stone Dr                                                                                                        |                                                                                                                                                                                                                                                                                                                                              |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            | 16. SIGNER                                                                    |                                                                                                                  |                                                         |                                 |                                       |  |
| c. COUNTY<br>Harris                                                                                                                               |                                                                                                                                                                                                                                                                                                                                              |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            | a. NAME (Type or print)<br>Joseph Frasier                                     |                                                                                                                  |                                                         | b. TELEPHONE<br>AREA CODE (850) |                                       |  |
| d. CITY<br>Tomball                                                                                                                                |                                                                                                                                                                                                                                                                                                                                              |                             | e. STATE<br>TX                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |                                                            | f. ZIP CODE<br>77375                                                          |                                                                                                                  | c. TITLE (Type or print)<br>Founder and Managing Member |                                 | NUMBER<br>356-2382                    |  |
| AUTHORIZED FOR LOCAL REPRODUCTION<br>Previous edition not usable                                                                                  |                                                                                                                                                                                                                                                                                                                                              |                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                            | STANDARD FORM 18 (REV. 6-95)<br>Prescribed by GSA<br>FAR (48 CFR) 53.215-1(a) |                                                                                                                  |                                                         |                                 |                                       |  |

## Section B - Supplies Or Services and Prices/Costs

| ITEM | SUPPLIES / SERVICES                                                                                                                                                                                                                                   | QTY / UNIT | UNIT PRICE              | EXTENDED PRICE               |
|------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|-------------------------|------------------------------|
| 0001 | <p>Modernized Application for Consumer and Healthcare Provider VAERS Reporting</p> <p>Firm Fixed Price<br/>Nonseverable Services</p> <p>Monthly Payments in Arrears</p> <p>Period of Performance:<br/>09/28/2026 – 06/27/2027</p>                     | 1 Job      | \$                      | \$                           |
| 0002 | <p>Non-Conference Travel for Onboarding</p> <p>All travel shall be conducted in accordance with Federal Travel Regulations.</p> <p>Direct Reimbursement<br/>Monthly Payments in Arrears</p> <p>Period of Performance:<br/>09/28/2026 – 06/27/2027</p> | 1 Job      | \$31,500.00<br>Estimate | \$31,500.00<br>Not-to-Exceed |
| 0003 | <p>Non-Conference Travel for Meetings</p> <p>All travel shall be conducted in accordance with Federal Travel Regulations.</p> <p>Direct Reimbursement<br/>Monthly Payments in Arrears</p> <p>Period of Performance:<br/>09/28/2026 – 06/27/2027</p>   | 1 Job      | \$31,500.00<br>Estimate | \$31,500.00<br>Not-to-Exceed |

## Section C - Performance Work Statement

**Title: Modernized Application for Consumer and Healthcare Provider VAERS Reporting**

### SECTION 1 – BACKGROUND

Vaccine Adverse Event Reporting System (VAERS) is a national early warning system for monitoring the safety of U.S.-licensed vaccines. The Centers for Disease Control and Prevention (CDC) seeks to improve VAERS reporting for both the public and healthcare providers through a mobile-friendly, desktop-compatible web application that increases usability, improves completeness and quality of submitted information, and reduces user burden.

This acquisition supports development of a modernized reporting experience that incorporates a redesigned VAERS landing page and navigation, a guided reporting workflow with branching logic for public versus healthcare-provider submitters, an intelligent validation that assists with form completion, customer centric tooltips, informational popups and reactive design site navigation, modern / reactive popup frequently asked questions (FAQ) features.

The solution shall protect Personally Identifiable Information (PII) and Protected Health Information (PHI) and support integration with existing VAERS systems and processes. The Contractor shall comply with applicable federal information security, privacy, and accessibility requirements, including HIPAA, the Privacy Act, Section 508, and FedRAMP requirements for the CDC-managed cloud environment used to process or store VAERS data.

Contractor authorization to develop and deploy on CDC infrastructure shall be governed by an Authority to Develop (ATD) issued by CDC in coordination with the Office of the Chief Information Officer (OCIO).

### SUBSECTION A – DEFINITIONS

- **ATD (Authority to Develop):** Authorization issued by CDC, coordinated with OCIO, permitting the Contractor to develop, locally test, update, and deploy the application on CDC infrastructure following review of adequate security and privacy documentation.
- **ATO (Authority to Operate):** is an official management decision by a designated federal authorizing official that permits an information system to operate and explicitly accepts the risk to organizational operations, assets, individuals, other organizations, and the Nation based on implemented security and privacy controls
- **Branching Logic:** Conditional form flow that presents or suppresses data fields based on submitter type (public vs. healthcare provider) and report characteristics (e.g., vaccine error with no adverse event).
- **EPLC:** Enterprise Performance LifeCycle, comprised of Initiation, Concept, Planning, Requirements Analysis, Design, Development, Test, Implementation, Operations & Maintenance, and Disposition where applicable.
- **FedRAMP:** Federal Risk and Authorization Management Program.
- **FISMA:** Federal Information Security Modernization Act (updated in 2014).
- **FITARA:** Federal Information Technology Acquisition Reform Act.
- **HIPAA:** Health Insurance Portability and Accountability Act of 1996, as amended, including applicable Privacy and Security Rules.
- **Low-Code / Configurable UI:** Application design that enables authorized CDC program personnel to make content and interface updates with limited developer support.
- **OCIO:** Office of the Chief Information Officer (CDC).
- **PHI:** Protected Health Information.

- **PII:** Personally Identifiable Information.
- **Section 508:** Section 508 of the Rehabilitation Act of 1973, as amended, and applicable HHS ICT accessibility requirements.
- **VAERS:** Vaccine Adverse Event Reporting System.

## SUBSECTION B - CDC Cloud Environment

### Hosting Environments

CDC operates in a hybrid mode, with systems locally as well as in the cloud. CDC provides access to a standard set of services on Amazon Web Services (AWS) as well as Microsoft Azure that are FedRAMP authorized.

#### MS Azure

CDC uses a variety of products from Microsoft Azure. These products are available from general purpose to memory intensive and high-throughput applications and are compatible with Infrastructure as a Service (IaaS) and Platform as a Service (PaaS) models. The Microsoft Azure services available include (but are not limited to):

- Virtual Machines (IaaS)
- Azure Managed Instance SQL (PaaS)
- Azure SQL Comparison (IaaS and PaaS)
  - Azure SQL Database (PaaS)
  - Azure SQL Managed Instance (PaaS)
  - SQL Server on Azure VMs (IaaS)
- Load Balancers
- Private endpoints
- Storage accounts shares
- Azure Logic apps
- Azure Web apps

#### AWS

CDC uses a variety of products from Amazon Web Services (AWS). These products range from virtual servers to database services and are compatible with Infrastructure as a Service (IaaS) and Platform as a Service (PaaS) models. Below is a list of the standard AWS products available, including but not limited to:

- Elastic Beanstalk
- Lambda
- DynamoDB
- Amazon Relational Database Service (RDS)
- Lake Formation
- Elastic Kubernetes Service (EKS)
- Elastic Container Service (EC2)
- DocumentDB
- Amazon Simple Email Service (SES)
- Amazon Simple Queue Service (SQS)
- ElastiCache

The full list of FedRAMP compliant products available as part of the Azure and AWS FedRAMP Audit Scopes may be considered for usage.

**EDAV**

Enterprise Data Analytics and Visualization (EDAV) is an Microsoft Azure cloud-based set of technologies, tools, and resources used to simplify data workflows and save time throughout the data process, from data collection to visualization and action. Services include (but are not limited to):

- Azure Data Factory
- Azure Data Lake
- Azure OpenAI API
- Azure Functions
- CDC Posit
- Databricks Data Warehouse
- CDC Chatbot based on OpenAI's GPT (Generative Pre-trained Transformer) architecture

**One CDC Data Platform (1CDP)**

1CDP is CDC's unified data platform, built on Palantir Foundry Software as a Service (SaaS) technology. For more information see [One CDC Data Platform | Data Modernization | CDC](#)

## SUBSECTION C – Program Management and Planning

The Government requires effective program management throughout the period of performance to ensure schedule adherence, risk mitigation, cost control, and clear communication between the Contractor and Government stakeholders.

**Government Outcomes Sought:**

- A well-structured, executable program management approach with proactive risk identification and mitigation.
- An agile development plan with key performance indicators (KPIs)
- Transparent, regular communication on progress, risks, staffing, and cost performance.
- A formal change control process that protects system architecture, scope, and performance standards.
- Infrastructure costs managed within an approved baseline, with explicit cost modeling.

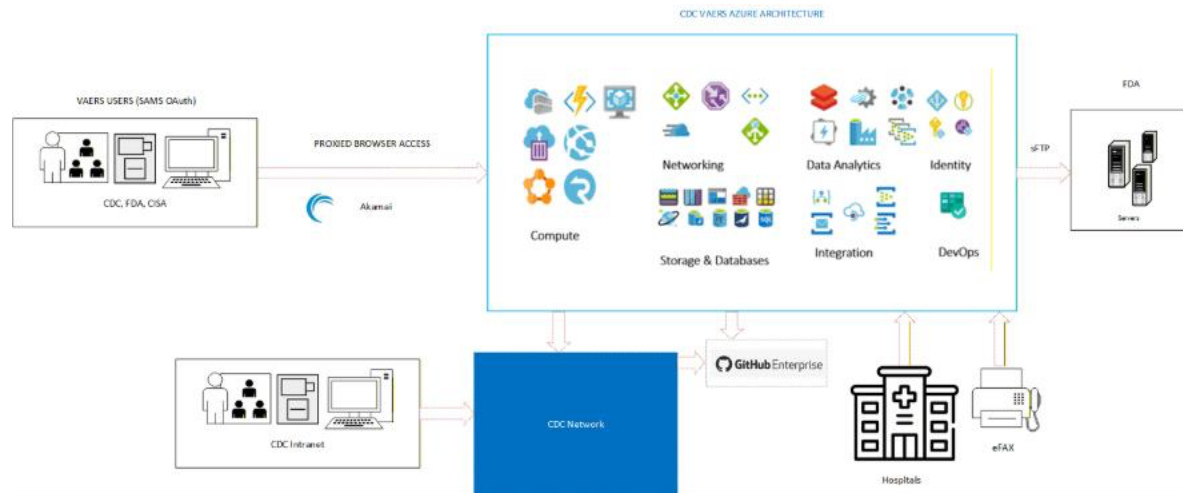
**Associated Tasks (Illustrative):**

- Project Management Plan (PMP) including work breakdown structure, milestone schedule, key personnel designations, and change control process.
- Project management deliverables in accordance with federal, HHS, and CDC EPLC requirements, including appropriate documentation, coordination, and approvals at the defined stage gates and the ATD and ATO authorization gate.
- Cost Management Plan modeling compute, storage, data transfer, and ancillary service costs at target operational throughput.
- Monthly status reports covering accomplishments, schedule progress, risks, staffing changes, and actual versus planned expenditure.
- Bi-weekly technical reviews with Government stakeholders.

## SUBSECTION D – Current Architecture

**VAERS Related Technical Information**

The VAERS system lies within the CDC-managed MS Azure cloud environment using Azure SQL Managed Instance databases and Virtual Machines that support the existing on-premises applications including, but not limited to ColdFusion, Tomcat, Node.js, MS .NET. Additional components include, but are not limited to Akamai, Blob Storage, Key Vault, Logic Apps and other Azure Functions. See architectural diagram on next page.



The VAERS website and reporting interface uses java and html and supports writable .pdf, CXone, and eFax.

## SECTION 2 – PURPOSE/OBJECTIVE

CDC requires design, development, and deployment of a modernized, mobile-friendly, desktop-compatible web application to support both public and healthcare-provider submission of VAERS reports. The purpose of this acquisition is to:

- Simplify and streamline the reporting experience for both public and healthcare-provider submitters while improving completeness and accuracy of submitted data.
- Redesign the VAERS landing page and navigation menus to provide clearer access to reporting tools, FAQs, and data downloads.
- Provide a branching-logic reporting workflow that tailors data fields to submitter type and report characteristics, using the data elements of the current VAERS form.
- Provide intelligent completion assistance, answers user questions, and supports site navigation, with tooltips and frequently asked questions
- Provide an integrated medical record upload capability while maintaining the existing post-submission upload tool.
- Enable authorized CDC program personnel to make interface and content updates with limited developer support, using current, state-of-the-art UI/UX design principles.
- Ensure security, privacy, and regulatory compliance for all data processed, including HIPAA and Privacy Act protections, FISMA and FedRAMP requirements, and Section 508 accessibility, and support issuance of an ATD.
- Produce VAERS-compatible data outputs and support integration with existing VAERS systems and processes.

## SECTION 3 – SCOPE OF WORK

Within the period of performance, the Contractor shall design, develop, test, and deliver a responsive, mobile-friendly, desktop-compatible web application that enables both the public and healthcare providers to submit VAERS reports with improved usability and data quality.

The scope includes human-centered user experience (UX) design; redesign of the VAERS landing page and navigation menus for clearer access to reporting tools, FAQs, and data downloads; front-end and back-end application development; a branching-logic report submission form supporting public and healthcare-provider submitters using the data elements of the current VAERS form; implementation intelligent validation to help users through report completion, answer questions, and assist with site navigation; an integrated follow-up information upload capability; a low-code/configurable interface enabling authorized CDC program personnel to make updates with limited developer support; and production of structured data compatible with VAERS requirements to support integration with existing VAERS systems and workflows, operating within the CDC-managed hosting environment in MS Azure.

The application shall employ current, state-of-the-art UI/UX design principles.

The Contractor shall coordinate with the other existing contracts supporting the VAERS system and CDC/OCIO hosting teams to stand up the necessary environment within CDC's cloud infrastructure, develop, and deploy the application after appropriate approvals, including issuance of an ATD.

The Contractor shall implement, document, and obtain approval for required governance stage gates, security, privacy, and accessibility controls for all data processed, including HIPAA and Privacy Act protections, FISMA and FedRAMP requirements for the CDC-managed cloud environment, and Section 508 conformance for the application and all contract deliverables.

CDC will provide coordination, feedback, VAERS integration requirements, and access to the CDC Azure environment as applicable.

## SECTION 4 – TASKS TO BE PERFORMED

### **Task 1: Design and Develop Mobile-Friendly, Desktop-Compatible Web Application**

1.1 The Contractor shall collaborate with CDC stakeholders to confirm functional requirements, VAERS data elements, integration constraints, and success metrics for both public and healthcare-provider reporting.

1.2 The Contractor shall produce UX artifacts (e.g., user flows, wireframes, and clickable prototypes) and incorporate CDC feedback prior to development, applying current, state-of-the-art UI/UX design principles.

1.3 The Contractor shall design and develop a responsive web application optimized for mobile devices and modern desktop browsers, enabling users to access and complete reporting from any device with internet access, including form validation, error handling, and user-friendly data entry to reduce reporting burden.

1.4 The Contractor shall redesign the VAERS landing page and navigation menus to provide clearer access to reporting tools, FAQs, and data downloads, including a link to the simplified report submission form (Task 1.6).

1.5 The Contractor shall implement a customer satisfaction survey for navigating the VAERS site.

1.6 The Contractor shall develop a mobile-friendly, desktop-compatible report submission form that uses branching logic to serve both public and healthcare-provider submitters using the data elements of the current VAERS form. The Contractor shall:

- 1.6.1 Substitute simpler, plain-language text for the public version that requires less health expertise.
- 1.6.2 Implement branching logic so that healthcare providers submitting a vaccine error report with no adverse event (AE) are not required to complete AE-related fields.

1.7 The Contractor shall implement a pop-up customer satisfaction survey presented upon VAERS submission to measure satisfaction with the submission process.

1.8 The Contractor shall implement a low-code/configurable interface enabling authorized CDC program personnel to make content and interface updates with limited developer support, and shall document the change and configuration process.

1.9 The Contractor shall implement VAERS-compatible data capture and ability to transmit data (e.g., structured data mappings) to support integration with existing VAERS systems and workflows, as directed by CDC.

1.10 The Contractor shall implement performance optimization to achieve page load time of  $\leq 3$  seconds under normal operating conditions, support a median end-to-end submission time of  $\leq 10$  minutes for typical reports, and reduce the submission abandonment rate by  $\geq 30\%$  compared to the baseline established at project kickoff.

1.11 The Contractor shall deliver working builds for Government review and conduct iterative defect remediation through beta and final release.

1.12 The Contractor shall develop user-facing documentation and support materials aligned with the final application user experience.

## **Task 2: Implement Medical Record Upload and Document Management**

2.1 The Contractor shall integrate an upload tool for medical record information as part of the form update, while maintaining the current upload tool for documents that become available post-submission.



2.2 The Contractor shall include a free-text box allowing submitters to provide additional information as free text.

2.3 The Contractor shall implement a tool that scans healthcare-provider submissions and suggests supplemental documents to upload.

2.4 The Contractor shall implement a two-phase approach to uploaded documents:

- 2.4.1 **Phase 1 (base scope):** Restrict accepted documents in the upload tool to medical records and vaccine documents related to vaccine administration or the adverse event reported.
- 2.4.2 **Phase 2 (optional / future phase, not in base scope):** Following Government evaluation of Phase 1, and if exercised as a future option or contract modification, allow healthcare providers to upload pictures and medical images related to the adverse event reported. The Contractor shall design Phase 1 to accommodate future Phase 2 expansion.

2.5 The Contractor shall ensure all upload and document-management functionality complies with security, privacy, and accessibility requirements for handling PHI/PII.

2.6 The Contractor shall remediate defects and optimize upload performance through beta and final release.

### **Task 3: Ensure Security, Privacy, FISMA, FedRAMP, HIPAA, Section 508 Compliance, and Support ATD Issuance**

3.1 The Contractor shall design, develop, and document the application in a manner that protects PHI and PII and supports compliance with HIPAA and the Privacy Act for all data collected, processed, transmitted, and stored.

3.2 The Contractor shall ensure the application is developed and deployed within the CDC-managed FedRAMP-authorized Azure environment approved for use by CDC, consistent with Government security requirements.

3.3 The Contractor shall prepare and submit adequate security and privacy documentation sufficient for CDC, in coordination with OCIO, to issue an Authority to Develop (ATD) enabling local testing, updates, and product deployment on CDC infrastructure. The Contractor shall address Government review comments and remediate identified weaknesses as a condition of ATD issuance.

3.4 The Contractor shall implement and document appropriate technical and administrative safeguards (e.g., access controls, encryption in transit and at rest, audit logging, and secure configuration) consistent with CDC direction. The Contractor shall perform application vulnerability scanning during development and before deployment to eliminate known vulnerabilities.

3.5 The Contractor shall ensure that the web application and all deliverables (including documentation) conform to Section 508 and applicable HHS ICT accessibility standards and shall provide an Accessibility Conformance Report (ACR/VPAT) and remediation plan for any nonconformities.

3.6 The Contractor shall prepare and submit required security, privacy, and compliance documentation identified in Section 8, and shall address Government review comments and identified weaknesses.

3.7 The Contractor shall conduct functional, security, and accessibility testing and remediate identified defects prior to beta and final release.

3.8 The Contractor shall provide user guides and administrator/technical guides sufficient to support CDC operation, maintenance, and future enhancements, including guidance for program-personnel configuration (Task 1.8).

## Task 4 – Transition Out

Preparations for Transition-Out should be started by the contractor in conjunction with the COR and technical/programmatic government staff early in the contract execution, developing a state of readiness for transition to both government staff and subsequent contractors. Materials should include links to all code repositories, accounts, rights, and necessary SOPs to continue execution of the functions.

The Contractor shall:

4.1 Maintain a Transition-out readiness posture where documentation is assessed **at least monthly** based on project delivery timeframes and provided to the COR and technical representatives. This should include (but is not limited to) any documentation, system and email and other account access, code bases, processes, and other assets necessary to understand and operate the systems and related procedures. These assets and the ability to assign access should always be available to designated FTEs to ensure continuity of operations.

4.2 Facilitate the transition out of contracted activities and services to the Federal Government or, to a follow-on Contractor by the end of the **contract** period of performance.

4.3 During the transition-out, ensure no degradation in support provided under the **contract**.

4.4 The incumbent Contractor shall submit to the COR, for approval, a detailed Transition-out Plan at least two (2) months prior to contract end. The plan shall identify tasks, roles, and responsibilities for contractor staff during the transition, and transition-out schedule and milestones to ensure an orderly and complete transition.

4.5 Lead Technical Exchange Meetings (TEMs) with the successor to impart knowledge transfer of all processes, projects, systems, applications, and databases, as well as sustainment activities.

4.6 Provide the government with the accurate and most current versions of all documentation developed under the TO.

4.7 Provide the government a current inventory of all Government-owned assets used by the Contractor along with full support in the reconciliation of this inventory.

4.8 Provide the government with access to full documentation of and all custom code, user accounts, and configurations (not COTS source code), reports, process automations, scripts and configurations with applicable configuration management information.

4.9 Provide current status and reference to materials for governance, security and privacy or other approval aspects of each project or activity.

4.10 Provide the successor with the ability to “shadow” and participate in other knowledge transfer meetings and opportunities to facilitate the transfer of information, processes, and data needed to continue the services being performed by the Contractor

4.11 Perform all **contract** closeout activities and provide sustainment support to complete the transition.

## SECTION 5 – GOVERNMENT FURNISHED PROPERTY

Personal Identity Verification (PIV) cards and laptops will be furnished by the government. CDC will provide access to the CDC-managed Azure environment for development, testing, and deployment, coordinated with OCIO and governed by the ATD.

## SECTION 6 – PLACE OF PERFORMANCE AND CONTRACT SUPPORT HOURS

### SUBSECTION A – PLACE OF PERFORMANCE

Primary place of performance is remote at the Contractor's facility(ies) within the United States. The Contractor shall coordinate routinely with CDC personnel located in Atlanta, Georgia, and shall participate in virtual meetings as required. Any on-site activities at CDC facilities, if requested by the Government, shall be coordinated in advance by the COR and shall comply with CDC security and facility access requirements.

### SUBSECTION B – CONTRACT SUPPORT HOURS

The Contractor shall provide contract support during CDC core business hours, Monday through Friday, 8:30 a.m. to 5:00 p.m. Eastern Time (ET), excluding Federal holidays. Support outside of core business hours may be requested by the Government on an as-needed basis for planned releases or time-sensitive activities and shall be coordinated in advance with the COR.

## SECTION 7 – TRAVEL

No travel, other than that necessary for employee onboarding, is anticipated for this contract. The Contractor shall perform work remotely and coordinate with CDC via virtual meetings. If the Government requests travel (e.g., for in-person meetings at CDC Atlanta), travel must be approved in advance by the COR and shall be reimbursed in accordance with applicable Federal Travel Regulation (FTR) requirements and the travel terms of the contract.

## SECTION 8 – DELIVERABLES/REPORTING SCHEDULE

Dates are re-baselined to a nine-month PoP. Deliverables shall be submitted electronically unless otherwise directed by the COR. The Contractor shall address Government comments and resubmit as requested.

| Task        | Deliverable                                                        | Quantity/Format           | Due Date                          | Deliver To    |
|-------------|--------------------------------------------------------------------|---------------------------|-----------------------------------|---------------|
| PM / Task 4 | Project Plan + Deployment and Hosting Plan (CDC/HHS-managed cloud) | 1 / MS Word               | Within 10 calendar days after DOA | COR (copy CO) |
| Task 1      | UX Wireframes, User Flows, and Landing Page/Navigation Redesign    | 1 set / PDF or web export | Within 21 calendar days after DOA | COR           |

|           |                                                                                                                                             |                                                                   |                                                          |               |
|-----------|---------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------|----------------------------------------------------------|---------------|
| Task 1    | Technical Design Document (incl. branching logic; low-code approach if retained)                                                            | 1 / MS Word                                                       | Within 30 calendar days after DOA                        | COR           |
| Task 1    | Working Prototype (Alpha) Demonstration Build                                                                                               | 1 / web application build<br>1 / deployable web application build | Within 45 calendar days after DOA                        | COR           |
| Tasks 1–3 | Beta Release                                                                                                                                |                                                                   | Within 90 calendar days after DOA                        | COR           |
| Task 2    | Customer centric design, intelligent form assistance, and usage metrics                                                                     | 1 / MS Word                                                       | With Beta Release                                        | COR           |
| Task 2    | Frequently Asked Questions Data Report                                                                                                      | 1 / MS Word or data export                                        | With Beta; updated with Final                            | COR           |
| Task 1    | Customer Satisfaction Survey Instruments (site navigation + post-submission pop-up)                                                         | 1 set / MS Word or web                                            | With Beta Release                                        | COR           |
| Task 3    | Phase 1 Upload Implementation and Phase 2 Design Provisions                                                                                 | 1 / MS Word                                                       | With Beta Release                                        | COR           |
| Task 4    | Security and Privacy Documentation Package Supporting ATD Issuance                                                                          | 1 package / MS Word + artifacts                                   | In advance of deployment to support ATD; draft with Beta | COR           |
| Task 4    | Compliance Documentation Package (Security/Privacy/Section 508)                                                                             | 1 package / MS Word + artifacts                                   | With Beta Release                                        | COR           |
| Task 4    | Accessibility Conformance Report (ACR/VPAT) and Remediation Plan                                                                            | 1 / ACR/VPAT                                                      | With Beta; updated with Final                            | COR           |
| Tasks 1–4 | Testing and Final Release (Production-Ready) and Source/Build Artifacts                                                                     | 1 / final deployable build                                        | By end of PoP (DOA + 150 days)                           | COR           |
| Tasks 1–4 | User Guides (Public, Healthcare Provider, Technical/Administrator); Operation and Management (O&M), Architecture Designs, Process Workflows | 3 / MS Word or PDF                                                | With Final Release                                       | COR           |
| PM        | Monthly Status Report                                                                                                                       | 1 per month / MS Word or PDF                                      | By the 10th calendar day of each month                   | COR           |
| PM        | Final Report / Project Closeout Summary                                                                                                     | 1 / MS Word                                                       | By end of PoP                                            | COR (copy CO) |

## SUBSECTION A – PERFORMANCE MATRIX

| Performance Objective                                                                                                                                                                                      | Standard                                                                                                             | Performance Threshold (AQL)                                                                     | Method of Surveillance                                           |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|------------------------------------------------------------------|
| PRS#1 Branching Logic Correctness (Task 1.6); Report submission form correctly serves public vs. healthcare-provider paths and suppresses AE-related fields for provider vaccine-error-with-no-AE reports. | 100% correct field presentation/suppression across Government-defined test scenarios for both submitter types.       | ≤ 1 non-critical defect per acceptance test cycle; no critical defects.                         | 100% Inspection during Government acceptance testing.            |
| PRS#2 Mobile/Desktop Responsiveness (Task 1.3); Application functions correctly on mobile devices and modern desktop browsers, enabling reporting from any internet-connected device.                      | Correct rendering and functional completion of core reporting flows across Government-defined device/browser matrix. | No critical defects; ≤ 2 high-severity defects at final release with approved remediation plan. | 100% Inspection at acceptance; Periodic Inspection through Beta. |

|                                                                                                                                                                                                                            |                                                                                                                                                                       |                                                                                                         |                                                                                     |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| PRS#3 Landing Page and Navigation Redesign (Task 1.4); Redesigned landing page and navigation provide clear access to reporting tools, FAQs, and data downloads, including link to the submission form.                    | All required access paths present, functional, and validated in Government review.                                                                                    | No critical defects; all required access paths functional at Final Release.                             | 100% Inspection at acceptance.                                                      |
| PRS#4 Application Performance (Task 1.10) — Measure-and-Report, Page load ≤ 3 seconds; median end-to-end submission time ≤ 10 minutes; submission abandonment reduced ≥ 30% vs. kickoff baseline.                          | Contractor measures and reports against targets using approved methodology; targets are not pass/fail acceptance gates per Task 1.10.                                 | Reports delivered; measured values documented with methodology; deviations explained.                   | Periodic Inspection of measurement reports; automated monitoring where implemented. |
| PRS#5 Data Completeness (Tasks 1.1, 1.6, 1.9); Required and critical VAERS data elements complete in submitted reports (public and provider).                                                                              | ≥ 90% completeness for required/critical VAERS data elements, measured via periodic analysis of submitted reports.                                                    | ≥ 85%.                                                                                                  | Periodic Inspection and Random Sampling; analytics review by Government.            |
| PRS#6 VAERS-Compatible Data Capture and Transmission (Task 1.9); End-to-end capture and transmission of VAERS-compatible structured data to existing VAERS systems and workflows, as directed by CDC.                      | Successful generation and transmission of VAERS-compatible structured data for all required fields in Government acceptance testing.                                  | ≤ 1 critical defect per acceptance test cycle.                                                          | 100% Inspection during Government acceptance testing.                               |
| PRS#7 Customer Satisfaction Surveys (Tasks 1.5, 1.7); Site-navigation survey and post-submission pop-up survey implemented and operational.                                                                                | Both surveys deployed, capturing responses, and results reported to Government at defined intervals.                                                                  | Both surveys deployed and functional at Final Release; response data delivered per approved schedule.   | 100% Inspection at acceptance; Periodic Inspection of survey data delivery.         |
| PRS#8 Program-Personnel Editability / Low-Code UI (Task 1.8); Authorized CDC program personnel can make defined content and interface updates with limited developer support; change and configuration process documented. | Government-defined update scenarios completed by program personnel without developer code changes; configuration/change process documentation delivered and approved. | ≤ 1 update scenario requiring developer intervention; documentation approved by COR.                    | 100% Inspection during Government acceptance testing.                               |
| PRS#9 Medical Record Upload Capability (Tasks 2.1, 2.2, 2.5); Integrated upload tool for medical records and free-text box for additional information, with existing post-submission upload tool maintained.               | Upload tool integrated in form, free-text box functional, existing post-submission tool preserved, and PHI/PII handling compliant.                                    | No critical defects; ≤ 2 high-severity defects at Final Release with approved remediation plan.         | 100% Inspection at acceptance; security review by Government.                       |
| PRS#10 Supplemental Document Suggestion Tool (Task 2.3); Tool scans healthcare-provider submissions and suggests supplemental documents to upload.                                                                         | Tool operational and providing suggestions across Government-defined provider test scenarios.                                                                         | ≥ 90% suggestion coverage across defined scenarios; no critical defects.                                | 100% Inspection during Government acceptance testing.                               |
| PRS#11 Two-Phase Upload — Phase 1 Implementation and Phase 2 Design Provisions (Task 2.4); Phase 1 restricts uploads to medical records and vaccine documents; design accommodates future Phase 2 expansion.               | Phase 1 upload restrictions enforced; design documentation demonstrating Phase 2 extensibility delivered.                                                             | Phase 1 restrictions correctly enforced with no critical defects; extensibility documentation approved. | 100% Inspection at acceptance; Periodic Inspection of design documentation.         |

|                                                                                                                                                                                                                                                                                 |                                                                                                                                                            |                                                                                                                                                              |                                                                                                          |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| PRS#12 ATD Issuance Support (Task 3.3)<br>— Security and privacy documentation sufficient for CDC (in coordination with OCIO) to issue ATD enabling local testing, updates, and deployment.                                                                                     | ATD issued by CDC based on Contractor-provided documentation; Government review comments addressed and identified weaknesses remediated.                   | ATD issued in advance of production deployment; no unresolved critical findings at issuance.                                                                 | 100% Inspection at ATD gate; Periodic Inspection of remediation.                                         |
| PRS#13 PHI/PII Protection and Security Safeguards (Tasks 3.1, 3.4); HIPAA/Privacy Act protection for data collected, processed, transmitted, stored; documented technical/administrative safeguards; vulnerability scanning eliminates known vulnerabilities before deployment. | Safeguards implemented and documented; vulnerability scanning performed during development and pre-deployment with no known vulnerabilities at deployment. | No known critical/high vulnerabilities at deployment; safeguards documented and approved.                                                                    | 100% Inspection at pre-deployment; Periodic Inspection of scan results.                                  |
| PRS#14 Section 508 Conformance (Task 3.5); Web application and all deliverables conform to Section 508 and HHS ICT accessibility standards; ACR/VPAT and remediation plan provided.                                                                                             | No critical/high-severity accessibility defects at Final Release; ACR/VPAT and remediation plan for any nonconformities delivered.                         | No critical defects; ≤ 3 high-severity defects open at Final Release with approved remediation plan.                                                         | Periodic Inspection (accessibility testing); 100% Inspection at acceptance.                              |
| PRS#15 Compliance Documentation Package (Task 3.6); Required security, privacy, and Section 508 documentation submitted; Government review comments addressed.                                                                                                                  | Complete package delivered per Section 8; Government comments addressed within agreed timeframes.                                                          | Package accepted by COR; no unresolved critical review comments at Final Release.                                                                            | 100% Inspection at delivery.                                                                             |
| PRS#16 User and Administrator Documentation (Tasks 1.12, 3.8); User-facing documentation and administrator/technical guides delivered, including program-personnel configuration guidance for Task 1.8.                                                                         | All user, technical/administrator, and configuration guides delivered, accepted by COR, and aligned with final application UX.                             | All required guides delivered and accepted by COR at Final Release.                                                                                          | 100% Inspection at delivery.                                                                             |
| PRS#17 Program Management and Reporting (Subsection C); PMP, monthly status reports, bi-weekly technical reviews, and Cost Management Plan delivered and current.                                                                                                               | PMP delivered and maintained; monthly status reports on schedule; bi-weekly technical reviews conducted; Cost Management Plan maintained.                  | ≥ 95% on-time delivery of PM deliverables; no missed bi-weekly reviews without prior COR agreement.                                                          | Periodic Inspection; COR review.                                                                         |
| PRS#18 Transition-Out Readiness (Tasks 4.1–4.9); Ongoing transition-readiness posture maintained; documentation assessed at least monthly; Transition-out Plan delivered ≥ 2 months prior to contract end; no degradation in support during transition.                         | Monthly transition-readiness assessment provided to COR; Transition-out Plan delivered on schedule and approved; TEMs conducted; no support degradation.   | Monthly assessments on time; Transition-out Plan delivered ≥ 2 months prior to end and approved; zero critical support degradation events during transition. | Periodic Inspection (monthly assessments); 100% Inspection at Transition-out Plan delivery and closeout. |

## SECTION 9 – REFERENCE MATERIALS

- Government-provided VAERS data element definitions, business rules, and integration requirements for public and healthcare-provider reporting (provided at kickoff).
- Applicable federal and HHS/CDC information security, privacy, and accessibility policies and standards, including HIPAA, the Privacy Act, Section 508, and FedRAMP requirements.
- CDC/OCIO ATD requirements and CDC-managed Azure environment security requirements (provided at kickoff).

## SECTION 10 – MINIMUM VENDOR QUALIFICATIONS

There are no minimum vendor qualifications beyond those evaluated under the solicitation's evaluation factors are specified in this PWS.

## SECTION 11 – ADDITIONAL REQUIREMENTS

### Information Security and Privacy

The Contractor shall comply with all applicable CDC, HHS, and federal information security and privacy requirements, including protections for PII and PHI under the Privacy Act and HIPAA. The Contractor shall implement security and privacy-by-design practices, including secure handling of PHI/PII during collection, processing, transmission, and storage, and shall use the CDC Azure environment (FedRAMP authorized and approved for use by CDC) to integrate with existing VAERS infrastructure. The Contractor shall provide adequate security and privacy documentation sufficient for CDC, in coordination with OCIO, to issue an Authority to Develop (ATD) to deploy and Authority to Operate (ATO) the application on CDC infrastructure and enable local testing, updates, and deployment, and shall support Government reviews by responding to findings and implementing approved remediation.

#### Information Security and Privacy Compliance

##### Standard-1: Procurements Requiring Information Security and/or Physical Access Security

1. Baseline Security Requirements
  - a. **Applicability.** The requirements herein apply whether the entire contract or modification (hereafter "contract"), or portion thereof, includes either or all of the followings. No contractor will be permitted to access or operate CDC infrastructure or systems overseas unless prior approval is received from CDC CISO.
    - i. **Access (Physical or Logical) to Government Information:** A Contractor (and/or any subcontractor) will have or will be given the ability to have, routine physical (entry) or logical (electronic) access to government information.
    - ii. **Operate a Federal System Containing Information:** A Contractor (and/or any subcontractor) will operate a federal system and information technology containing data that supports the CDC mission. In addition to the Federal Acquisition Regulation (FAR) Subpart 2.1 definition of "information technology" (IT), the term as used in this section includes computers, ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including support services), and related resources.
  - b. **Safeguarding Information and Information Systems.** All government information and information systems must be protected in accordance with HHS/CDC policies and level of risk. At a minimum, the Contractor (and/or any subcontractor) must:
    - i. Protect the:

- **Confidentiality**, which means preserving authorized restrictions on access and disclosure, based on the security terms found in this contract, including means for protecting personal privacy and proprietary information;
  - **Integrity**, which means guarding against improper information modification or destruction, and ensuring information non-repudiation and authenticity; and
  - **Availability**, which means ensuring timely and reliable access to and use of information.
- ii. Categorize all information owned and/or collected/managed on behalf of CDC and information systems that store, process, and/or transmit HHS information in accordance with FIPS 199 and National Institute of Standards and Technology ([NIST Special Publication \(SP\) 800-60, Volume II: Appendices to Guide for Mapping Types of Information and Information Systems to Security Categories](#)). Based on information provided by the ISSO, CISO, CDC CPO, or other representative, the impact level for each Security Objective (Confidentiality, Integrity, and Availability) and the Overall Impact Level, which is the highest watermark of the three factors of the information or information system are the following:
  - **Confidentiality:**                    ☐ Low   ☒ Moderate   ☐ High
  - **Integrity:**                                ☐ Low   ☒ Moderate   ☐ High
  - **Availability:**                            ☐ Low   ☒ Moderate   ☐ High
  - **Overall Impact Level:**                ☐ Low   ☒ Moderate   ☐ High
- iii. Based on the agreed-upon level of impact, implement the necessary safeguards to protect all information systems and information collected and/or managed on behalf of CDC regardless of location or purpose.
- iv. Report any discovered or unanticipated threats or hazards by either the agency or contractor, or if existing safeguards have ceased to function immediately after discovery, **within one (1) hour or less**, to the government representative(s).
- v. Adopt and implement all applicable policies, procedures, controls, and standards required by the CDC Information Security Program to ensure the confidentiality, integrity, and availability of government information and government information systems for which the Contractor is responsible under this contract or to which the Contractor may otherwise have access under this contract. Obtain all applicable security and privacy policies by contacting the CO/COR or CDC security and/or privacy officials.
- c. **Privacy Act.** Comply with the Privacy Act requirements (when applicable), and tailor FAR and HHSAR clauses as needed.
- d. **Privacy Compliance.** Comply with the E-Government Act of 2002, NIST SP 800-53, and applicable CDC privacy policies, and complete all the requirements below:
  - i. Per the Office of Management and Budget (OMB) Circular A-130, Personally Identifiable Information (PII), is "information that can be used to distinguish or trace an individual's identity, either alone or when combined with other information that is linked or linkable to a specific individual." Examples of PII include, but are not limited to the following: Social Security number, date and place of birth, mother's maiden name, biometric records, etc.
  - ii. To ensure that the public's personal information is protected in a manner commensurate with the privacy risks, CDC uses a privacy analysis process to assess the risks associated with CDC's collection and maintenance of PII and to ensure information is handled in accordance with applicable legal, regulatory, and policy requirements. PTAs analyze how information is handled in IT systems and electronic information collections and determines if the IT system or electronic information collection collects, disseminates, maintains, or disposes of PII. PIAs are used to assess the privacy risks of IT systems and electronic information collections that collect, disseminate, maintain, or dispose of PII about members of the public. PIAs also provide transparency into how CDC collects, disseminates, maintains, or disposes of the public's PII.



- iii. The Contractor must support the agency with conducting a Privacy Threshold Analysis (PTA) for the information system and/or information handled under this contract to determine whether or not PII is collected, disseminated, maintained, or disposed as part of the contract. The PTA will determine if a full Privacy Impact Assessment (PIA) needs to be completed.
- If the results of the PTA show that a full PIA is needed, the Contractor must support the agency with completing a PIA for the system or information within *60 days* after completion of the PTA and in accordance with CDC policy and OMB M-03-22, *Guidance for Implementing the Privacy Provisions of the E-Government Act of 2002*.
  - The Contractor must support the agency in reviewing the PIA at least every *three years* throughout the system development lifecycle (SDLC)/information lifecycle, or when determined by the agency that a review is required based on a major change to the system, or when new types of PII are collected that introduces new or increased privacy risks, whichever comes first.
- e. **Controlled Unclassified Information (CUI). Executive Order 13556** defines CUI as "information that laws, regulations, or Government-wide policies require to have safeguarding or dissemination controls, excluding classified information." The Contractor (and/or any subcontractor) must comply with *Executive Order 13556, Controlled Unclassified Information, (implemented at 3 CFR, part 2002)* when handling CUI. 32 C.F.R. 2002.4(aa) As implemented the term "*handling*" refers to "...any use of CUI, including but not limited to marking, safeguarding, transporting, disseminating, re-using, and disposing of the information." 81 Fed. Reg. 63323. The requirements below apply only to nonfederal systems that process, store, or transmit CUI, or that provide security protection for such components. All sensitive information that has been identified as CUI by a regulation or statute, handled by this solicitation/contract, must be:
- i. Marked appropriately;
  - ii. Disclosed to authorized personnel on a Need-To-Know basis;
  - iii. Protected in accordance with NIST SP 800-53, *Security and Privacy Controls for Information Systems and Organizations* applicable baseline if handled by a Contractor system operated on behalf of the agency, or NIST SP 800-171, *Protecting Controlled Unclassified Information in Nonfederal Information Systems and Organizations* if handled by internal Contractor system; and
  - iv. Returned to HHS/CDC control, destroyed when no longer needed, or held until otherwise directed. Information and/or data must be disposed of in accordance with NIST SP 800-88, *Guidelines for Media Sanitization*.
- f. **Protection of Sensitive Information.** For security purposes, information is *or* may be sensitive because it requires security to protect its confidentiality, integrity, and/or availability. The Contractor (and/or any subcontractor) must protect all government information that is or may be sensitive by securing it with a solution that is validated with current FIPS 140 validation certificate from the NIST CMVP.
- g. **Confidentiality and Nondisclosure of Information.** Any information provided to the contractor (and/or any subcontractor) by CDC or collected by the contractor on behalf of CDC must be used only for the purpose of carrying out the provisions of this contract and must not be disclosed or made known in any manner to any persons except as may be necessary in the performance of the contract. The Contractor assumes responsibility for protection of the confidentiality of Government records and must ensure that all work performed by its employees and subcontractors must be under the supervision of the Contractor. Each Contractor employee or any of its subcontractors to whom any CDC records may be made available or disclosed must be notified in writing by the Contractor that information disclosed to such employee or subcontractor can be used only for that purpose and to the extent authorized herein.

The confidentiality, integrity, and availability of such information must be protected in accordance with HHS/CDC policies. Unauthorized disclosure of information will be subject to the HHS/CDC sanction policies and/or governed by the following laws and regulations:

- i. 18 U.S.C. 641 (Criminal Code: Public Money, Property or Records);
    - ii. 18 U.S.C. 1905 (Criminal Code: Disclosure of Confidential Information); and
    - iii. 44 U.S.C. Chapter 35, Subchapter I (Paperwork Reduction Act).
  - h. **Internet Protocol Version 6 (IPv6).** All procurements using Internet Protocol must comply with OMB Memorandum M-05-22, *Transition Planning for Internet Protocol Version 6 (IPv6)*.
  - i. **Information and Communications Technology (ICT).** ICT products and services from prohibited entities/sources must not be used/acquired in compliance with Public Law 115-232, Section 889 Parts A and B, FAR 4.21, FAR 52.204.23, FAR 52.204.24, and FAR 52.204.25. The contractor (and/or any subcontractor) must notify the government if they identify prohibited ICT products and/or services are used during the contract performance.
  - j. **Government Websites.** All new and existing public-facing government websites must be securely configured with Hypertext Transfer Protocol Secure (HTTPS) using the most recent version of Transport Layer Security (TLS). In addition, HTTPS must enable HTTP Strict Transport Security (HSTS) to instruct compliant browsers to always assume HTTPS to reduce the number of insecure redirects and protect against attacks that attempt to downgrade connections to plain HTTP. For internal-facing websites, HTTPS is not required, but it is highly recommended. Consult *HHS/CDC Policy for Internet and Email Security* for additional information.
  - k. **Contract Documentation.** The Contractor must use provided templates, policies, forms and other agency documents *specify which documents/forms will be provided to contractor* to comply with contract deliverables as appropriate.
  - l. **Standard for Encryption.** The Contractor (and/or any subcontractor) must:
    - i. Comply with the *HHS Standard for Encryption of Computing Devices and Information* to prevent unauthorized access to government information.
    - ii. Encrypt all sensitive federal data and information (i.e., PII, protected health information [PHI], proprietary information, etc.) in transit (i.e., email, network connections, etc.) and at rest (i.e., servers, storage devices, mobile devices, backup media, etc.) with encryption solution that is validated with current FIPS 140 validation certificate from the NIST CMVP.
    - iii. Secure all devices (i.e.: desktops, laptops, mobile devices, etc.) that store and process government information and ensure devices meet and CDC Component-specific encryption standard requirements. Maintain a complete and current inventory of all laptop computers, desktop computers, and other mobile devices and portable media that store or process sensitive government information (including PII).
    - iv. Verify that the encryption solutions in use have been validated under the Cryptographic Module Validation Program to confirm compliance with current FIPS 140 validation certificate from the NIST CMVP. The Contractor must provide a written copy of the validation documentation to the COR.
    - v. Use the Key Management system on the CDC personal identification verification (PIV) card or establish and use a key recovery mechanism to ensure the ability for authorized personnel to encrypt/decrypt information and recover encryption keys <http://csrc.nist.gov/publications/>. Encryption keys must be provided to CSPO.
  - m. **Contractor Non-Disclosure Agreement (NDA).** Each Contractor (and/or any subcontractor) employee having access to non-public government information under this contract must complete the CDC non-disclosure agreement, as applicable. Contractors (and/or subcontractors) must submit a copy of each signed and witnessed NDA to the Contracting Officer (CO) and/or CO Representative (COR) prior to performing any work under this acquisition.
2. Training Requirements
- a. **Mandatory Training for All Contractor Staff.** All Contractor (and/or any subcontractor) employees assigned to work on this contract must complete the applicable CDC Contractor Information Security

Awareness, Privacy, and Records Management training (provided upon contract award) before performing any work under this contract. Thereafter, the employees must complete CDC *Security Awareness, Privacy, and Records Management* training at least **annually**, during the life of this contract. All provided training must be compliant with CDC training policies.

- b. **Role-based Training.** All Contractor (and/or any subcontractor) employees with significant security responsibilities (as determined by the program manager) must complete role-based training **annually** commensurate with their role and responsibilities in accordance with HHS/CDC policy and the *CDC Role-Based Training (RBT) of Personnel with Significant Security Responsibilities*.
  - c. **Training Records.** The Contractor (and/or any subcontractor) must maintain training records for all its employees working under this contract in accordance with CDC policy. A copy of the training records must be provided to the CO and/or COR within **30 days** after contract award and **annually** thereafter or upon request.
3. Rules of Behavior
- a. The Contractor (and/or any subcontractor) must ensure that all employees performing on the contract comply with *CDC Implementation of the HHS Rules of Behavior for Use of HHS Information Technology Resources*.
  - b. All Contractor employees performing on the contract must read and adhere to the Rules of Behavior before accessing agency data or other information, systems, and/or networks that store/process government information, initially at the beginning of the contract and at least **annually** thereafter, which may be done as part of annual CDC Information Security Awareness Training. If the training is provided by the contractor, the signed ROB must be provided as a separate deliverable to the CO and/or COR per defined timelines above.
4. Incident Response
- a. The Contractor (and/or any subcontractor) must respond to all alerts/Indicators of Compromise (IOCs) provided by CDC Computer Security Incident Response Center (CSIRC) IRT teams **within 24 hours**, whether the response is positive or negative. In accordance with FISMA and OMB M-17-12, *Preparing for and Responding to a Breach of Personally Identifiable Information (PII)*<sup>1</sup>, an incident is "an occurrence that (1) actually or imminently jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information or an information system; or (2) constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies" and a privacy breach is "the loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where (1) a person other than an authorized user accesses or potentially accesses personally identifiable information or (2) an authorized user accesses or potentially accesses personally identifiable information for an other than authorized purpose." For additional information on the CDC breach response process, please see the *CDC Standard for Responding to Breaches of Personally Identifiable Information (PII)*.<sup>2</sup>
  - b. Contracts with entities that collect, maintain, use, or operate Federal information or information systems on behalf of CDC must include in the following requirements:
    - i. The contractor shall cooperate with and exchange information with CDC officials, as deemed necessary by the CDC Breach Response Team, to report and manage of a suspected or confirmed breach.
    - ii. All contractors and subcontractors shall properly encrypt PII in accordance with OMB Circular A-130 and other applicable policies, including CDC-specific policies, and comply with HHS-specific policies for protecting PII. To this end, all contractors and subcontractors shall protect all sensitive

<sup>1</sup> Memorandum is available at: [https://www.whitehouse.gov/wp-content/uploads/legacy\\_drupal\\_files/omb/memoranda/2017/m-17-12\\_0.pdf](https://www.whitehouse.gov/wp-content/uploads/legacy_drupal_files/omb/memoranda/2017/m-17-12_0.pdf)

<sup>2</sup> Standard is available at: <https://cdc.sharepoint.com/teams/OCIO-CSPO-PUBDOCS/Standards/CSPO%20Responding%20to%20Breaches%20of%20Personally%20Identifiable%20Information.pdf>

information, including any PII created, stored, or transmitted in the performance of this contract, with encryption solution that is validated with the current FIPS 140 validation certificate from the NIST CMVP.

- iii. All contractors and subcontractors shall participate in regular training on how to identify and report a breach
  - iv. NOT notify affected individuals unless so instructed by the Contracting Officer or designated representative. If instructed by the Contracting Officer or representative, the Contractor must send [CDC Component] approved notifications to affected individuals *[insert CDC Component Specific timeline, process, and format]*.
  - v. Report all suspected and confirmed information security and privacy incidents and breaches to the CSPO Incident Response Team (IRT) *[CDC Component inserted contact information should be cited here]*, COR, CO, CDC CPO (or his or her designee), and other stakeholders, including breaches involving PII, in any medium or form, including paper, oral, or electronic, as soon as possible and without unreasonable delay, no later than **one (1) hour**, and consistent with the applicable CDC Component and CDC policy and procedures, NIST standards and guidelines, as well as US-CERT notification guidelines. The types of information required in an incident report must include at a minimum: company and point of contact information, impact classifications/threat vector, and the type of information compromised. In addition, the Contractor must:
    - Cooperate and exchange any information, as determined by the Agency, necessary to effectively manage or mitigate a suspected or confirmed breach;
    - Not include any sensitive information in the subject or body of any reporting e-mail; and
    - Encrypt sensitive information in attachments to email, media, etc.
  - vi. Comply with OMB M-17-12, *Preparing for and Responding to a Breach of Personally Identifiable Information*, and CDC Component and CSPO privacy breach response policies when handling PII breaches.
  - vii. Provide full access and cooperate on all activities as determined by the Government to ensure an effective incident response, including providing all requested images, log files, and event information to facilitate rapid resolution of sensitive information incidents. This may involve disconnecting the system processing, storing, or transmitting the sensitive information from the Internet or other networks or applying additional security controls. This may also involve physical access to contractor facilities during a breach/incident investigation *[CDC Component insert timeline if required]*.
  - viii. All contractors and subcontractors shall be able to determine what Federal information was or could have been accessed and by whom, construct a timeline of user activity, determine methods and techniques used to access Federal information, and identify the initial attack vector.
  - ix. Cloud service providers shall use guidance provided in the FedRAMP Incident Communications Procedures when deciding when to report directly to US-CERT first or notify CDC first.
  - x. Acknowledge that CDC will not interpret report of a breach, by itself, as conclusive evidence that the contractor or its subcontractor failed to provide adequate safeguards for PII.
5. Position Sensitivity Designations

All Contractor (and/or any subcontractor) employees must obtain a background investigation commensurate with their position sensitivity designation that complies with Parts 1400 and 731 of Title 5, Code of Federal Regulations (CFR). The following position sensitivity designation levels apply to this solicitation/contract:

#### 6. Homeland Security Presidential Directive (HSPD)-12

The Contractor (and/or any subcontractor) and its employees must comply with Homeland Security Presidential Directive (HSPD)-12, *Policy for a Common Identification Standard for Federal Employees*

and Contractors; OMB M-05-24; OMB M-19-17; FIPS 201, *Personal Identity Verification (PIV) of Federal Employees and Contractors*; CDC HSPD-12 policy; and *Executive Order 13467, Part 1 §1.2*.

## 7. Roster

The Contractor (and/or any subcontractor) must submit a roster by name, position, e-mail address, phone number and responsibility, of all staff working under this acquisition where the Contractor will develop, have the ability to access, or host and/or maintain a government information system(s). The roster must be submitted to the COR and/or CO 30 days prior to the effective date of this contract. Any revisions to the roster as a result of staffing changes must be submitted immediately upon the 30 days change. The COR will notify the Contractor of the appropriate level of investigation required for each staff member.

If the employee is filling a new position, the Contractor must provide a position description and the Government will determine the appropriate suitability level.

| Investigation                                                       | Position Requirement                                                                                               |
|---------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|
| <input type="checkbox"/> NAC                                        | National Agency Check                                                                                              |
| <input type="checkbox"/> Tier 1                                     | Low-Risk Non-Sensitive, including HSPD-12 Credentialing                                                            |
| <input checked="" type="checkbox"/> Tier 2 (with subject interview) | Moderate-Risk Public Trust (MRPT)                                                                                  |
| <input type="checkbox"/> Tier 3                                     | Non-Critical Sensitive, National Security, including Secret and "L" access eligibility                             |
| <input type="checkbox"/> Tier 4                                     | High-Risk Public Trust                                                                                             |
| <input type="checkbox"/> Tier 5                                     | Critical Sensitive and Special Sensitive, National Security, including Top Secret, SCI, and "Q" access eligibility |
| <input type="checkbox"/> Not Applicable                             | No Requirement                                                                                                     |

## 8. Contract Initiation and Expiration

- a. **General Security Requirements.** The Contractor (and/or any subcontractor) must comply with information security and privacy requirements, Enterprise Performance Life Cycle (EPLC) processes, CDC Enterprise Architecture requirements to ensure information is appropriately protected from initiation to expiration of the contract. All information systems development or enhancement tasks supported by the contractor must follow the CDC EPLC framework and methodology and in accordance with the CDC Office of Financial Resources (OFR) Contract Closeout Guide and *HHS Closeout Guide: Contracts and Orders*.
- b. **System Documentation.** Contractors (and/or any subcontractors) must follow and adhere to CDC System Development Life Cycle requirements, at a minimum, for system development and provide system documentation at designated intervals (specifically, at the expiration of the contract) within the EPLC that require artifact review and approval.
- c. **Sanitization of Government Files and Information.** As part of contract closeout and at expiration of the contract, the Contractor (and/or any subcontractor) must provide all required documentation to the CO and/or COR to certify that, at the government's direction, all electronic and paper records are appropriately disposed of and all devices and media are sanitized in accordance with NIST SP 800-88, *Guidelines for Media Sanitization*.
- d. **Notification.** The Contractor (and/or any subcontractor) must notify the CO and/or COR and system ISSO within 15 days before an employee stops working under this contract.
- e. **Contractor Responsibilities upon Physical Completion of the Contract.** The contractor (and/or any subcontractors) must return all government information and IT resources (i.e., government information in non-government-owned systems, media, and backup systems) acquired during the term of this contract to the CO and/or COR. Additionally, the Contractor must provide a certification that all government information has been properly sanitized and purged from Contractor-owned systems, including backup systems and media used during contract performance, in accordance with CDC policies.

- f. The Contractor (and/or any subcontractor) must perform and document the actions identified in the *CDC Out-Processing Checklist* ([http://intranet.cdc.gov/od/hcrmo/pdfs/hr/Out\\_Processing\\_Checklist.pdf](http://intranet.cdc.gov/od/hcrmo/pdfs/hr/Out_Processing_Checklist.pdf)) when an employee terminates work under this contract within 15 days of the employee's exit from the contract. All documentation must be available to the CO and/or COR upon request.

9. Records Management and Retention

- a. The Contractor (and/or any subcontractor) must maintain all information in accordance with Executive Order 13556 -- Controlled Unclassified Information, National Archives and Records Administration (NARA) records retention policies and schedules and *CDC Policy for Records Management* and *HHS policies* and must not dispose of any records unless authorized by *CDC Program*.
- b. If a contractor (and/or any subcontractor) accidentally disposes of or destroys a record without proper authorization, he/she must document and report the incident in accordance with CDC policies.

10. High Value Asset (HVA):

If a system is identified as HVA, the contractor must comply with the HHS Policy for the High Value Asset (HVA) Program and the Department of Homeland Security (DHS) HVA Control Overlay<sup>[22]</sup> in addition to the above requirements.

11. Deliverables

| Deliverable Title/Deliverable Type                                   | Description                                                           | Due Date                                                                                                                                         |
|----------------------------------------------------------------------|-----------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| Roster                                                               | Roster                                                                | Within 30 days of the effective date of this contract                                                                                            |
| Contractor Employee Non-Disclosure Agreement (NDA)                   | Contractor Employee Non-Disclosure Agreement (NDA)                    | Prior to performing any work on behalf of HHS                                                                                                    |
| Privacy Threshold Analysis (PTA)/ Privacy Impact Assessment (PIA)    | Assist in the completion of a PTA/PIA form                            | Within 60-90 days after contract award                                                                                                           |
| Training Records                                                     | Copy of training records for all mandatory training                   | In conjunction with contract award and annually thereafter or upon request                                                                       |
| Rules of Behavior                                                    | Signed ROB for all employees                                          | Initiation of contract and at least annually thereafter                                                                                          |
| Incident Response                                                    | Incident Report (as incidents or breaches occur)                      | As soon as possible and without reasonable delay and no later than 1 hour of discovery                                                           |
| Personnel Security Responsibilities                                  | List of Personnel with defined roles and responsibilities             | Within 7 days; that is before an employee begins working on this contract.                                                                       |
| Personnel Security Responsibilities                                  | Off-boarding documentation, equipment and badge when leaving contract | Within 5 days or less after the Government's final acceptance of the work under this contract, or in the event of a termination of the contract. |
| Background Investigation                                             | Onboarding documentation when beginning contract.                     | Prior to performing any work on behalf of HHS                                                                                                    |
| Certification of Sanitization of Government and Government Activity- | Form or deliverables required by CDC                                  | At contract expiration.                                                                                                                          |

|                                          |                                                                                                                                         |                         |
|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|-------------------------|
| Related Files, Information, and Devices. |                                                                                                                                         |                         |
| Contract Initiation and Expiration       | If the procurement involves a system or cloud service, additional documentation will be required, such as Disposition/Decommission Plan | At contract expiration. |

## Standard-2 Requirements for Procurements Involving Privacy

Appropriate security controls and Rules of Behavior should be incorporated to protect the confidentiality of information, proprietary, sensitive, and Personally Identifiable Information (PII) the Contractor may come in contact with during the performance of this contract.

## Standard-3 Procurements Involving Government Information Processed on GOCO or COCO Systems

### 1. Security Requirements for GOCO and COCO Resources

- a. **Federal Policies.** The Contractor (and/or any subcontractor) must comply with applicable federal laws, directives and CDC policies that include, but are not limited to, *HHS Information Security and Privacy Policy (IS2P)*, the CDC IT Security Program Implementation Standards, *Federal Information Security Modernization Act (FISMA) of 2014, (44 U.S.C. 101)*; National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, latest revision, *Security and Privacy Controls for Information Systems and Organizations*; Office of Management and Budget (OMB) Circular A-130, *Managing Information as a Strategic Resource*; and other applicable federal laws, regulations, NIST guidance, and agency policies.
- b. **Security Assessment and Authorization (SA&A).** A valid authority to operate (ATO) certifies that the Contractor's information system meets the contract's requirements to protect the agency data. If the system under this contract does not have a valid ATO, the Contractor (and/or any subcontractor) must work with the agency and supply the deliverables required to complete the ATO prior to any use of the system in a production capacity, i.e., its intended users able to collect, store, process or transmit data to fulfill the system's function. within the specified timeline(s). The Contractor must conduct the SA&A requirements in accordance with *HHS IS2P/CDC IT Security Program implementation standard and Appendix K: CDC Organizationally Defined Minimum Numbers and Time Periods Derived from NIST SP 800-53 Revision 5*, NIST SP 800-37, *Guide for Applying the Risk Management Framework to Information Systems: A Security Life Cycle Approach* (latest revision), NIST SP 800-53B, *Control Baselines for Information Systems and Organizations*, and the NIST SP 800-53A (latest revision).

CDC acceptance of the ATO does not alleviate the Contractor's responsibility to ensure the system security and privacy controls are implemented and operating effectively.

- i. **SA&A Package Deliverables** - The Contractor (and/or any subcontractor) must provide an SA&A A package *timeline, process, and formats proscribed for a Full system authorization* in the CDC Security Assessment and Authorization Standard Operating Procedure (CDC SA&A SOP). The following SA&A deliverables are required to complete the SA&A package.
  - **Baseline System Information (BSI)** – The Contractor will document a system overview, in accordance with the timeline, process and formats described in the *CDC SA&A SOP*. The BSI will include information concerning system identification and ownership; system data, information types, impact levels and system categorization; system functional description / general purpose; system authorization boundary and environment; system user descriptions; and system interconnections and dependencies. The Contractor shall update the BSI at least **annually** thereafter.



- **Privacy Threshold Analysis / Privacy Impact Analysis** – The Contractor (and/or any subcontractor) shall provide a PTA/PIA (as appropriate), in accordance with the timeline, process and formats described in the *CDC SA&A SOP*, if applicable. Also see the sections of this contract concerning “Privacy Threshold Analysis (PTA)/Privacy Impact Assessment (PIA)” and “Requirements for Procurements Involving Privacy Act Records.” **NOTE:** If social security numbers (SSN) are expected to be handled by the system, the program and Contractor must include a *SSN Elimination or Usage Approval Request* along with the PTA/PIA. That request will be processed in accordance with the *CSPO Standard for Limiting the Use of Social Security Numbers in CDC Information Systems*.
- **System Security Plan (SSP)** – due in accordance with contract. The SSP must be provided in a digital format supporting copy or export of all content into the HHS/CDC automated SA&A tool. The SSP must comply with the NIST SP 800-18, *Guide for Developing Security Plans for Federal Information Systems*, the Federal Information Processing Standard (FIPS) 200, *Recommended Security Controls for Information Systems*, and NIST SP 800-53, *Security and Privacy Controls for Federal Information Systems and Organizations* applicable baseline requirements, and other applicable NIST guidance as well as CDC policies and other guidance. The SSP must be consistent with and detail the approach to IT security contained in the Contractor's bid or proposal that resulted in the award of this contract. The SSP must provide an overview of the system environment and security requirements to protect the information system as well as describe all applicable security controls in place or planned for meeting those requirements. It should provide a structured process for planning adequate, cost-effective security protection for a system. The Contractor must review and update the SSP at least **annually** thereafter and if requested, provide a copy of the updated SSP.
- **Risk Assessment Report (RAR)** – The initial security assessment shall be conducted by the Contractor in conjunction with the program’s Information System Security Officer, consistent with NIST SP 800-53A, NIST SP 800-30, and HHS and CDC policies. The assessor will document the assessment results in the RAR, in accordance with the process and formats described in the CDC SA&A SOP. The Contractor shall address all “High” deficiencies before submitting the package to the Government for acceptance. All remaining deficiencies must be documented in a system Plan of Actions and Milestones (POA&M) for CDC CSPO approval in accordance with the CDC SA&A SOP. Thereafter, the Contractor, in coordination with CDC shall conduct an assessment of the security controls and update the RAR within 365 days.
- **POA&M** – The POA&M shall be documented consistent with the HHS Standard for Plan of Action and Milestones and CDC policies. Identified risks stemming from deficiencies related to the security control baseline implementation, assessment, continuous monitoring, vulnerability scanning, and other security reviews and sources, as documented in the Security or Risk Assessment Report (SAR/RAR), shall be documented and tracked by the Contractor for mitigation in the POA&M document. Depending on the severity of the risks, CDC may require designated POAM weaknesses to be remediated before an ATO is issued. Thereafter, the POA&M shall be updated at least **quarterly**.  
  
All critical-risk weaknesses must be mitigated within *15 days*, high-risk weaknesses must be mitigated within 30 days, medium weaknesses must be mitigated within 60 days, and low weaknesses must be mitigated within 360 days from the date the weaknesses are formally identified.
- **Contingency Plan and Contingency Plan Test** – The Contingency Plan must be developed in accordance with NIST SP 800-34, *Contingency Planning Guide for Federal Information Systems*, and be consistent with HHS/CDC policies. Upon acceptance by the System Owner, the Contractor, in coordination with the System Owner, must test the Contingency Plan and prepare a Contingency Plan Test Report that includes the test



results, lessons learned and any action items that need to be addressed. Thereafter, the Contractor must update and test the Contingency Plan at least **annually**.

- **E-Authentication Assessment** - The contractor (and/or any subcontractor) must collaborate with government personnel to ensure that the E-Authentication requirements are implemented in accordance with OMB 04-04 and NIST SP 800-63-3, NIST SP 800-63A, NIST SP 800-63B, and NIST SP 800-63C.

Based on the level of assurance determined by the E-Auth, the Contractor (and/or subcontractor) must ensure appropriate authentication to the system, including remote authentication, is in-place in accordance with the assurance level determined by the E-Auth (when required) in accordance with CDC *CSPO Standard for Electronic Authentication (E-Authentication)*; and the *CDC SA&A SOP*.

- ii. **Information Security Continuous Monitoring.** Upon the government issuance of an Authority to Operate (ATO), the Contractor (and/or subcontractor)-owned/operated systems that input, store, process, output, and/or transmit government information, must meet or exceed the information security continuous monitoring (ISCM) requirements in accordance with FISMA and NIST SP 800-137, *Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations*, HHS ISCM Strategy, and CDC IT Security Program implementation standard and Appendix K: CDC Organizationally Defined Minimum Numbers and Time Periods Derived from NIST SP 800-53 Revision 5.
- iii. **Annual Assessment/Penetration (Pen) Test** - Assess the system security and privacy controls (or ensure an assessment of the controls is conducted) at least annually to determine the implemented security and privacy controls are operating as intended and producing the desired results (this involves penetration testing conducted by the agency or independent third-party. In addition, review all relevant SA&A documentation (SSP, POA&M, Contingency Plan, etc.) and provide updates by specified due date
- iv. **Asset Management** - Using any available Security Content Automation Protocol (SCAP)-compliant automated tools for active/passive scans, provide an inventory of all information technology (IT) assets for hardware and software, (computers, servers, routers, databases, operating systems, etc.) that are processing CDC-owned information/data. It is anticipated that this inventory information will be required to be produced at least annually. IT asset inventory information must include IP address, machine name, operating system level, security patch level, and SCAP-compliant format information. The contractor must maintain a capability to provide an inventory of 100% of its IT assets using SCAP-compliant automated tools in accordance with the *Office of Safety, Security, and Asset Management (OSSAM)* and any other applicable CDC policy.
- v. **Configuration Management** - Use available SCAP-compliant automated tools as per NIST IR 7511 and *CDC Organizationally-Defined Minimum Numbers and Time Periods Derived from NIST SP 800-53*, to scan all IT assets, including but not limited to: computers, servers, routers, databases, operating systems, application, etc., that store and process government information. Provide scan reports to CDC upon request. The contractor must maintain a capability to provide security configuration compliance information for 100% of its IT assets using SCAP-compliant automated tools.
- vi. **Vulnerability Management** - Contractors must actively manage system vulnerabilities using automated tools and technologies where practicable and in accordance with *CDC Policy for Vulnerability Management*. Automated tools must be compliant with NIST-specified SCAP standards for vulnerability identification and management. The contractor must maintain a capability to provide security vulnerability scanning information for 100% of IT assets using SCAP-compliant automated tools and report to the agency at least **annually**.

|                   |                |
|-------------------|----------------|
| <b>Critical</b> – | within 15 days |
| <b>High</b> –     | within 30 days |
| <b>Medium</b> –   | within 90 days |

**Low –** within 360 days

- vii. **Patching and Vulnerability Remediation** - Install vendor released security patches and remediate critical and high vulnerabilities in systems processing government information in an expedited manner, within vendor and agency specified timeframes per CSPO Vulnerability Remediation Framework Standard.
  - viii. **Secure Coding** - Follow the *HHS Policy for Software Development Secure Coding Practices* and the *CDC Secure Software Development Standard* for secure coding best practice requirements, as directed by United States Computer Emergency Readiness Team (US-CERT) specified standards and the Open Web Application Security Project (OWASP), that will limit system software vulnerability exploits.
  - ix. **Boundary Protection** - The contractor must ensure that government information, other than unrestricted information, being transmitted from federal government entities to external entities is routed through a Trusted Internet Connection (TIC).
- c. **Government Access for Security Assessment.** In addition to the Inspection Clause in the contract, the Contractor (and/or any subcontractor) must afford the Government access to the Contractor's facilities, installations, operations, documentation, information systems, and personnel used in performance of this contract to the extent required to carry out a program of security assessment (to include vulnerability testing), investigation, and audit to safeguard against threats and hazards to the confidentiality, integrity, and availability of federal data or to the protection of information systems operated on behalf of CDC, including but are not limited to:
- i. At any tier handling or accessing information, consent to and allow the Government, or an independent third party working at the Government's direction, without notice at any time during a weekday during regular business hours contractor local time, to access contractor and subcontractor installations, facilities, infrastructure, data centers, equipment (including but not limited to all servers, computing devices, and portable media), operations, documentation (whether in electronic, paper, or other forms), databases, and personnel which are used in performance of the contract.
- The Government includes but is not limited to the U.S. Department of Justice, U.S. Government Accountability Office, and the HHS Office of the Inspector General (OIG). The purpose of the access is to facilitate performance inspections and reviews, security and compliance audits, and law enforcement investigations. For security audits, the audit may include but not be limited to such items as buffer overflows, open ports, unnecessary services, lack of user input filtering, cross site scripting vulnerabilities, SQL injection vulnerabilities, and any other known vulnerabilities.
- ii. At any tier handling or accessing protected information, fully cooperate with all audits, inspections, investigations, forensic analysis, or other reviews or requirements needed to carry out requirements presented in applicable law or policy. Beyond providing access, full cooperation also includes, but is not limited to, disclosure to investigators of information sufficient to identify the nature and extent of any criminal or fraudulent activity and the individuals responsible for that activity. It includes timely and complete production of requested data, metadata, information, and records relevant to any inspection, audit, investigation, or review, and making employees of the contractor available for interview by inspectors, auditors, and investigators upon request. Full cooperation also includes allowing the Government to make reproductions or copies of information and equipment, including, if necessary, collecting a machine or system image capture.
    - Segregate Government protected information and metadata on the handling of Government protected information from other information. Commingling of information is prohibited. Inspectors, auditors, and investigators will not be precluded from having access to the sought information if sought information is commingled with other information.
    - Cooperate with inspections, audits, investigations, and reviews.

- d. **End of Life Compliance.** The Contractor (and/or any subcontractor) must use Commercial off the Shelf (COTS) software or other software that is supported by the manufacturer. In addition, the COTS/other software need to be within one major version of the current version; deviation from this requirement will only be allowed via the HHS waiver process (approved by CDC CISO). The contractor must retire and/or upgrade all software/systems that have reached end-of-life in accordance with *HHS/CDC End of Life Operating Systems, Software and Application Policy*.
- e. **Desktops, Laptops, and Other Computing Devices Required for Use by the Contractor.** The Contractor (and/or any subcontractor) must ensure that all IT equipment (e.g., laptops, desktops, servers, routers, mobile devices, peripheral devices, etc.) used to process information on behalf of CDC are deployed and operated in accordance with approved security configurations and meet the following minimum requirements:
  - i. Encrypt equipment and sensitive information stored and/or processed by such equipment in accordance with CDC encryption standard and current FIPS 140 validation certificate from the NIST CMVP.
  - ii. Configure laptops and desktops in accordance with the latest applicable United States Government Configuration Baseline (USGCB), *[CDC Component insert specific security configuration baseline if any]*, and HHS Minimum Security Configuration Standards<sup>3</sup>;
  - iii. Maintain the latest operating system patch release and anti-virus software definitions monthly.
  - iv. Validate the configuration settings after hardware and software installation, operation, maintenance, update, and patching and ensure changes in hardware and software do not alter the approved configuration settings; and
  - v. Automate configuration settings and configuration management in accordance with CDC security policies, including but not limited to:
    - Configuring its systems to allow for periodic CDC vulnerability and security configuration assessment scanning; and
    - Using Security Content Automation Protocol (SCAP)-validated tools with capabilities to scan its systems at least on a monthly basis and report the results of these scans to the CO and/or COR, Project Officer, and any other applicable designated POC.
- f. **Change Management.** Once a system is authorized, all changes must be approved by CDC in accordance with NIST SP 800-53, *Security and Privacy Controls for Federal Information Systems and Organizations*; the *HHS IS2P*; and the timeline, process and formats proscribed in the *CDC CSPO Change Management Standard Operating Procedure*.
- g. **Retirement / Decommissioning.** When the CDC program and Contractor determine the system is no longer required, it must be decommissioned in accordance NIST SP 800-88, *Guidelines for Media Sanitization*; the *HHS IS2P*; and the timeline, process and formats proscribed in the *CDC CSPO System Retirement Standard Operating Procedure*.
- h. **Rights to Data.** All contracts that require data to be produced, furnished, acquired, or used in meeting contract performance requirements, must contain terms that delineate the respective rights and obligations of the Government and the contractor regarding the use, reproduction, and disclosure of that data. Data rights clauses do not specify the type, quantity or quality of data that is to be delivered, but only the respective rights of the Government and the contractor regarding the use, disclosure, or reproduction of the data. Accordingly, the contract must specify the data to be delivered.
- i. **Information and Communications Technology (ICT) Cybersecurity Supply Chain Risk Management (C-SCRM) requirements.** The Contractor (and/or any subcontractor) must secure their ICT supply chain in compliance with *HHS Policy for Cyber Supply Chain Risk Management* and Public Law 115-232 § 889. At a minimum, they must implement the following:

---

Minimum Security Configuration Standards Guidance is available at <https://intranet.hhs.gov/policy/security-config-standard<sup>3</sup>>

- i. Develop rules for suppliers' development methods, techniques, or practices;
  - ii. Use of secondary market components;
  - iii. Prohibit counterfeit products;
  - iv. Dispose and/or retain elements such as components, data, or intellectual property securely;
  - v. Ensure adequate supply of components;
  - vi. Require external providers handling federal information or operating systems on behalf of the federal government to meet the same security and privacy requirements as federal agencies;
  - vii. Require external providers to express security and privacy requirements (including the controls for systems processing, storing, or transmitting federal information) in contracts or other formal agreements;
  - viii. Establish Service Level Agreements (SLAs), patching vehicles and disclosure requirements in the case of a security incident or new vulnerability being discovered;
  - ix. Ensure that the supplier applies same contractual requirements to any sub-contractors/suppliers that they involve in the provision of the product or service to the customer; and
  - x. Prohibit the use of covered telecommunications and video surveillance equipment or services.
- j. Deliverables

| Deliverable Title/Deliverable Type           | Description                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Due Date                                            |
|----------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------|
| Security Assessment and Authorization (SA&A) | SA&A Package <ul style="list-style-type: none"> <li>• SSP</li> <li>• SAR</li> <li>• POA&amp;M</li> <li>• Authorization Letter</li> <li>• CP and CPT Report</li> <li>• E-Auth (if applicable)</li> <li>• PTA/PIA (if applicable)</li> <li>• Interconnection/Data Use Agreements (if applicable)</li> <li>• Authorization Letter</li> <li>• Configuration Management Plan (if applicable)</li> <li>• Configuration Baseline</li> <li>• Other CDC-specific documents</li> </ul> | Due within 120 days of system planned go-live date. |

#### Standard-4. Contracts Involving Cloud Services

##### 1. HHS/CDC FedRAMP Privacy and Security Requirements.

The Contractor (and/or any subcontractor) must be responsible for the following privacy and security requirements:

- a. **FedRAMP Compliant ATO.** Comply with FedRAMP Security Assessment and Authorization (SA&A) requirements and ensure the information system/service under this contract has a valid FedRAMP compliant (approved) authority to operate (ATO) in accordance with Federal Information Processing Standard (FIPS) Publication 199 defined security categorization. If a FedRAMP compliant ATO has not been granted, the Contractor must submit a plan to obtain a FedRAMP compliant ATO by 120 days.
  - i. Implement applicable FedRAMP baseline controls commensurate with the agency-defined security categorization and the applicable FedRAMP security control baseline ([www.FedRAMP.gov](http://www.FedRAMP.gov)). The *HHS Information Security and Privacy Policy (IS2P)* and *HHS Cloud Computing and Federal Risk and Authorization Management Program (FedRAMP) Guidance* further define the baseline policies as well as roles and responsibilities. The Contractor must also implement a set of additional controls identified by the agency when applicable.

- ii. A security control assessment must be conducted by a FedRAMP third-party assessment organization (3PAO) for the initial ATO and **annually** thereafter or whenever there is a significant change to the system's security posture in accordance with the FedRAMP Continuous Monitoring Plan.
  - b. **Data Jurisdiction.** The contractor must store all information within the security authorization boundary, data at rest or data backup, within the Continental United States (CONUS) if so required.
  - c. **Service Level Agreements.** The Contractor must understand the terms of the service agreements that define the legal relationships between cloud customers and cloud providers and work with CDC to develop and maintain an SLA.
  - d. **Interconnection Agreements/Memorandum of Agreements.** The Contractor must establish and maintain Interconnection Agreements and or Memorandum of Agreements/Understanding in accordance with HHS/CDC policies.
2. Protection of Information in a Cloud Environment
- a. If contractor (and/or any subcontractor) personnel must remove any information from the primary work area, they must protect it to the same extent they would the proprietary data and/or company trade secrets and in accordance with HHS/CDC policies.
  - b. HHS/CDC will retain unrestricted rights to federal data handled under this contract. Specifically, HHS/CDC retains ownership of any user created/loaded data and applications collected, maintained, used, or operated on behalf of HHS/CDC and hosted on contractor's infrastructure, as well as maintains the right to request full copies of these at any time. If requested, data must be available to HHS/CDC within **one (1) business day** from request date or within the timeframe specified otherwise. In addition, the data must be provided at no additional cost to HHS/CDC.
  - c. The Contractor (and/or any subcontractor) must ensure that the facilities that house the network infrastructure are physically and logically secure in accordance with FedRAMP requirements and HHS/CDC policies.
  - d. The contractor must support a system of records in accordance with NARA-approved records schedule(s) and protection requirements for federal agencies to manage their electronic records in accordance with 36 CFR § 1236.20 & 1236.22 (ref. a), including but not limited to the following:
    - i. Maintenance of links between records and metadata, and
    - ii. Categorization of records to manage retention and disposal, either through transfer of permanent records to NARA or deletion of temporary records in accordance with NARA-approved retention schedules.
  - e. The disposition of all HHS/CDC data must be at the written direction of HHS/CDC. This may include documents returned to HHS/CDC control; destroyed; or held as specified until otherwise directed. Items returned to the Government must be hand carried or sent by certified mail to the COR.
    - i. If the system involves the design, development, or operation of a system of records on individuals, the Contractor must comply with the Privacy Act requirements contract language herein related to "Requirements for Procurements Involving Privacy Act Records".
3. Security Assessment and Authorization (SA&A) Process
- a. The Contractor (and/or any subcontractor) must comply with CDC and FedRAMP requirements as mandated by federal laws, regulations, and CDC policies, including making available any documentation, physical access, and logical access needed to support the SA&A requirement. The level of effort for the SA&A is based on the system's FIPS 199 security categorization and CDC security policies.
    - i. In addition to the FedRAMP compliant ATO, the contractor must complete and maintain an agency SA&A package to obtain agency ATO prior to system deployment/service implementation. The agency ATO must be approved by the [CDC Component] authorizing official (AO) prior to implementation of system and/or service being acquired.

- ii. CSP systems must leverage a FedRAMP accredited third-party assessment organization (3PAO).
    - iii. For all acquired cloud services, the SA&A package must contain the following documentation. Following the initial ATO, the Contractor must review and maintain the ATO in accordance with HHS/CDC policies.
  - b. CDC reserves the right to perform penetration testing (pen testing) on all systems operated on behalf of agency. If CDC exercises this right, the Contractor (and/or any subcontractor) must allow CDC employees (and/or designated third parties) to conduct Security Assessment activities to include control reviews in accordance with CDC requirements. Review activities include, but are not limited to, scanning operating systems, web applications, wireless scanning; network device scanning to include routers, switches, and firewall, and IDS/IPS; databases and other applicable systems, including general support structure, that support the processing, transportation, storage, or security of Government information for vulnerabilities.
  - c. The Contractor must identify any gaps between required FedRAMP Security Control Baseline/Continuous Monitoring controls and the contractor's implementation status as documented in the Security Assessment Report and related Continuous Monitoring artifacts. In addition, the contractor must document and track all gaps for mitigation in a Plan of Action and Milestones (POA&M) document. Depending on the severity of the risks, CDC may require remediation at the contractor's expense before CDC issues an ATO.
  - d. The Contractor (and/or any subcontractor) must mitigate security risks for which they are responsible, including those identified during SA&A and continuous monitoring activities. All vulnerabilities and findings must be remediated, in accordance with timelines specified in the CDC POA&M Standard, from discovery: (1) critical vulnerabilities no later than **fifteen (15) days** and (2) high within **thirty (30) days** (3) medium within **ninety (90) days** and (4) low vulnerabilities no later than **three hundred and sixty (360) days** [or shorter timelines provided by CDC Component]. In the event a vulnerability or other risk finding cannot be mitigated within the prescribed timelines above, they must be added to the designated POA&M and mitigated within the newly designated timelines. CDC will determine the risk rating of vulnerabilities using FedRAMP baseline:
    - **15 days** for critical weaknesses;
    - **30 days** for high weaknesses;
    - **90 days** for medium weaknesses; and
    - **360 days** for low weakness.
  - e. **Revocation of a Cloud Service.** HHS and CDC/CISO have the right to take action in response to the CSP's lack of compliance and/or increased level of risk. In the event the CSP fails to meet HHS and FedRAMP security and privacy requirements and/or there is an incident involving sensitive information, HHS and/or CDC may suspend or revoke an existing agency ATO (either in part or in whole) and/or cease operations. If an ATO is suspended or revoked in accordance with this provision, the CO and/or COR may direct the CSP to take additional security measures to secure sensitive information. These measures may include restricting access to sensitive information on the Contractor information system under this contract. Restricting access may include disconnecting the system processing, storing, or transmitting the sensitive information from the Internet or other networks or applying additional security controls.
4. Reporting and Continuous Monitoring
- a. Following the initial ATOs, the Contractor (and/or any subcontractor) must perform the minimum ongoing continuous monitoring activities specified below, submit required deliverables by the specified due dates, and meet with the system/service owner and other relevant stakeholders to discuss the ongoing continuous monitoring activities, findings, and other relevant matters. The CSP will work with the agency to schedule ongoing continuous monitoring activities.
  - b. At a minimum, the Contractor must provide the following artifacts/deliverables on a monthly basis:

Application and Host Scans (if applicable) according to CSPO ISCM guidance.

- i. Perform periodic Authenticated Vulnerability Scans and Application Scans (if applicable) according to CSPO ISCM guidance
  - ii. Perform weekly scans (at a minimum) and provide results to CDC Component ISSO and CSPO ISCM for systems with a FIPS 199 impact level of High, HVA, or if the system contains PII, and ensure scan results are submitted in either CSV or PDF format
  - iii. Remediate vulnerabilities in accordance with CSPO Vulnerability Remediation Framework Policy
  - iv. Advise the CDC Component ISSO for any instance when critical/high vulnerabilities cannot be remediated as in accordance with the CSPO Vulnerability Framework Standard
  - v. Submit monthly Authenticated Vulnerability scans and Application scans (if applicable) to CDC (business owner) and CDC Component ISSO Operating system, database, Web application, and network vulnerability scan results;
  - vi. Updated POA&Ms;
  - vii. Any updated authorization package documentation as required by the annual attestation/assessment/review or as requested by the *[CDC Component]* System Owner or AO; and,
  - viii. Any configuration changes to the system and/or system components or CSP's cloud environment, that may impact CDC *[CDC Component]*'s security posture. Changes to the configuration of the system, its components, or environment that may impact the security posture of the system under this contract must be approved by the agency.
- c. Business Stewards (such as System Owner):
- i. Confirm Vendor/Contractor is performing Authenticated Vulnerability Scans and Application Scans (if applicable) according to CSPO ISCM guidance
  - ii. Review monthly Authenticated Vulnerability Scans and Application Scans (if applicable); Develop POA&Ms as needed
  - iii. Submit monthly Authenticated Vulnerability Scans and Application Scans (if applicable) to CSPO ISCM
  - iv. Submit written waiver requests to the CISO when systems cannot comply with the provisions of this standard
  - v. Track remediation/mitigation of security gaps to closure

## 5. Configuration Baseline

- a. The contractor must certify that applications are fully functional and operate correctly as intended on systems using *CDC Minimum Security Configurations Standards Guidance*. The standard installation, operation, maintenance, updates, and/or patching of software must not alter the configuration settings from the approved CDC *configuration* baseline.
- b. The contractor must use Security Content Automation Protocol (SCAP) validated tools with configuration baseline scanner capability to certify their products operate correctly with CDC and NIST defined configurations and do not alter these settings.

## 6. Incident Reporting

- a. The Contractor (and/or any subcontractor) must provide an Incident and Breach Response Plan (IRP) in accordance with CDC, OMB, and US-CERT requirements and obtain approval from the CDC

Component. In addition, the Contractor must follow the incident response and US-CERT reporting guidance contained in the FedRAMP Incident Communications.

- b. The Contractor (and/or any subcontractor) must implement a program of inspection to safeguard against threats and hazards to the security, confidentiality, integrity, and availability of federal data, afford CDC access to its facilities, installations, technical capabilities, operations, documentation, records, and databases within 72 hours of notification. The program of inspection must include, but is not limited to:
  - i. Conduct authenticated and unauthenticated operating system/network/ database/Web application vulnerability scans. Automated scans can be performed by CDC personnel, or agents acting on behalf of CDC using agency-operated equipment and/or specified tools. The Contractor may choose to run its own automated scans or audits, provided the scanning tools and configuration settings are compliant with NIST Security Content Automation Protocol (SCAP) standards and have been approved by the agency. The agency may request the Contractor's scanning results and, at the agency discretion, accept those in lieu of agency performed vulnerability scans.
  - ii. In the event an incident involving sensitive information occurs, cooperate on all required activities determined by the agency to ensure an effective incident, or breach response and provide all requested images, log files, and event information to facilitate rapid resolution of sensitive information incidents. In addition, the Contractor must follow the agency reporting procedures and document the steps it takes to contain and eradicate the incident, recover from the incident, and provide a post-incident report that includes at a minimum the following:
    - Company and point of contact name;
    - Contract information;
    - Impact classifications/threat vector;
    - Type of information compromised;
    - A summary of lessons learned; and
    - Explanation of the mitigation steps of exploited vulnerabilities to prevent similar incidents in the future.

#### 7. Media Transport

- a. The Contractor and its employees must be accountable and document all activities associated with the transport of government information, devices, and media transported outside controlled areas and/or facilities. These include information stored on digital and non-digital media (e.g., CD-ROM, tapes, etc.), mobile/portable devices (e.g., USB flash drives, external hard drives, and SD cards).
- b. All information, devices and media must be encrypted with HHS/CDC-approved encryption mechanisms to protect the confidentiality, integrity, and availability of all government information transported outside of controlled facilities.

#### 8. Boundary Protection: Trusted Internet Connections (TIC):

- a. The contractor must ensure that government information, other than unrestricted information, being transmitted from federal government entities to external entities using cloud services is inspected by Trusted Internet Connection (TIC) processes that are in compliance with the requirements of the Office of Management and Budget (OMB) Memorandum (M) 19-26: Update to the TIC Initiative, TIC 3.0.
- b. The contractor must route all external connections through a TIC.
- c. **Non-Repudiation.** The contractor must provide a system that implements encryption with current FIPS 140 validation certificate from the NIST CMVP that provides for origin authentication, data integrity, and signer non-repudiation.

#### 9. Deliverables

| Deliverable Title | Description | Due Date |
|-------------------|-------------|----------|
|-------------------|-------------|----------|



|                                                  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |                                                                                                                                          |
|--------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| Protection of Information in a Cloud Environment | Contract expiration                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Due within [insert contract-specific timeline] after contract award.                                                                     |
| SA&A Process for Cloud Services                  | <ul style="list-style-type: none"> <li>• SA&amp;A Package</li> <li>• SSP</li> <li>• SAR</li> <li>• POA&amp;M</li> <li>• CMP</li> <li>• CP and CPT Report</li> <li>• E-Auth (if applicable)</li> <li>• PTA/PIA (if applicable)</li> <li>• Penetration Test Results</li> <li>• Interconnection/Data Use/Agreements (if applicable)</li> <li>• Service Level Agreement</li> <li>• Authorization Letter</li> <li>• Configuration Management Plan (if applicable)</li> <li>• Configuration Baseline</li> <li>• Other CDC-specific documents</li> </ul> | Due within 120 days of system planned go-live date.                                                                                      |
| Reporting and Continuous Monitoring              | <ul style="list-style-type: none"> <li>• POA&amp;M updates;</li> <li>• Revised security documentation/Agreements</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                       | Monthly/as requested by CDC                                                                                                              |
| Security Alerts, Advisories, and Directives      | List of personnel with designated roles and responsibilities                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | Within 10 days; that is before an employee begins working on this contract.                                                              |
| Incident Reporting                               | <ul style="list-style-type: none"> <li>• Incident reports (as needed)</li> <li>• Incident Response Plan</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                | <ul style="list-style-type: none"> <li>• Incidents within one (1) hour;</li> <li>• Incident Response Plan as part of Proposal</li> </ul> |

#### Standard-11: Custom Code Development

##### Custom Code Development

As required by the Federal Source Code Policy set out in OMB Memo M-16-21, all computer software first produced in the performance of this contract shall be open-source software and shall be available for Government-wide use and for use by the public with data use rights under FAR 52.227-14 Rights in Data - General, unless otherwise specified in writing by the contract officer. The Contractor {and/or any subcontractor} shall maintain, at all times, a working, current and fully documented copy of all project or activity custom-developed source code in a repository from the CDC Recognized List of Source Code Repositories.

The Contractor (and/or any subcontractor) shall follow secure coding best practice requirements, as directed by the United States Computer Emergency Readiness Team (US-CERT) specified standards and the Open Web Application Security Project (OWASP) that will limit system software vulnerability exploits.

##### Deliverables:

| Deliverable Title | Description | Due Date |
|-------------------|-------------|----------|
|-------------------|-------------|----------|

|                              |                                                                                                                                                 |                                                                                                               |
|------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| Custom Developed Source Code | Computer software, including the source code uploaded to approved CDC repository ( <a href="https://it-guides.cdc">https://it-guides.cdc</a> ). | Ongoing throughout performance on work on behalf of CDC at a minimum of bi-weekly and at contract expiration. |
|------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|

## Human Subjects Protections in Research

Not applicable. This effort is limited to software design and development. If the Government directs activity that constitutes human subjects research, it will provide applicable requirements and approvals, and the Contractor shall comply prior to conducting such activities.

## Paperwork Reduction Act (PRA)

The Government will determine PRA applicability. The branching-logic form, simplified public text, and new survey instruments may affect public-facing data collection and trigger PRA review; the Contractor shall provide technical descriptions as requested. Recommend early CO/PRA engagement.

## Section 508 Compliance

HHSAR 352.239-78 (Provision) and 352.239-79 (Clause), Electronic and Information Technology Accessibility, apply (Deviation versions as issued by the 508 clearance official). Applicable standards include WCAG 2.0 Level A & AA success criteria, functional performance criteria, interoperability with assistive technology, applications, authoring tools, and support documentation/services. The chatbot, upload, and (if retained) low-code configuration interfaces shall all be within the scope of the ACR/VPAT. Nonconformities identified after award shall be remediated at the Contractor's expense.

508 accessibility standards applicable to this contract or order are identified as follows:

- 205 WCAG 2.0 Level A & AA Success Criteria
- 302 Functional Performance Criteria
- 502 Inoperability with Assistive Technology
- 503 Applications
- 504 Authoring Tools
- 602 Support Documentation
- 603 Support Services

## Printing

Not applicable. Electronic deliverables only, unless otherwise directed by the COR.

## CDC On-Campus Access

CDC on-campus access via Smart Card, if required for any coordinated on-site activity.

## Section D – Contract Terms and Conditions

### 1. FAR 52.252-2 Clauses Incorporated by Reference (FEB 1998)

This contract incorporates one or more clauses by reference, with the same force and effect as if they were given in full text. Upon request, the Contracting Officer will make their full text available. Also, the full text of a clause may be accessed electronically at this/these address(es):

<http://www.acquisition.gov/far-overhaul>

(End of clause)

| FAR SOURCE     | TITLE AND DATE                                                                                                                                                            |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 52.203-6 Alt I | Restrictions on Subcontractor Sales to the Government (JUN 2020) (NOV 2021)                                                                                               |
| 52.203-13      | Contractor Code of Business Ethics and Conduct (NOV 2021)                                                                                                                 |
| 52.203-17      | Contractor Employee Whistleblower Rights (NOV 2023)                                                                                                                       |
| 52.203-19      | Prohibition on Requiring Certain Internal Confidentiality Agreements or Statements (JAN 2017)                                                                             |
| 52.204-13      | System for Award Management Maintenance (DEVIATION) (RFO AUG 2025)                                                                                                        |
| 52.209-6       | Protecting the Government's Interest When Subcontracting With Contractors Debarred, Suspended, Proposed for Debarment, or Voluntarily Excluded (DEVIATION) (RFO APR 2026) |
| 52.209-9       | Updates of Publicly Available Information Regarding Responsibility Matters (DEVIATION) (RFO APR 2026)                                                                     |
| 52.209-10      | Prohibition on Contracting with Inverted Domestic Corporations (DEVIATION) (RFO APR 2026)                                                                                 |
| 52.212-4       | Contract Terms and Conditions—Commercial Products and Commercial Services (DEVIATION) (RFO APR 2026)                                                                      |
| 52.219-4       | Notice of Price Evaluation Preference for HUBZone Small Business Concerns (DEVIATION) (APR 2026)                                                                          |
| 52.219-6       | Notice of Total Small Business Set-Aside (DEVIATION) (RFO APR 2026)                                                                                                       |
| 52.219-14      | Limitations on Subcontracting (DEVIATION) (RFO APR 2026)                                                                                                                  |
| 52.219-8       | Utilization of Small Business Concerns (DEVIATION) (RFO APR 2026)                                                                                                         |
| 52.222-3       | Convict Labor (DEVIATION) (RFO APR 2026)                                                                                                                                  |
| 52.222-35      | Equal Opportunity for Veterans (DEVIATION) (RFO APR 2026)                                                                                                                 |
| 52.222-36      | Equal Opportunity for Workers with Disabilities (DEVIATION) (RFO APR 2026)                                                                                                |
| 52.222-37      | Employment Reports on Veterans (DEVIATION) (RFO APR 2026)                                                                                                                 |
| 52.222-40      | Notification of Employee Rights Under the National Labor Relations Act (DEVIATION) (APR 2026)                                                                             |
| 52.222-50      | Combating Trafficking in Persons (DEVIATION) (RFO APR 2026)                                                                                                               |
| 52.222-54      | Employment Eligibility Verification (DEVIATION) (RFO APR 2026)                                                                                                            |
| 52.222-90      | Addressing DEI Discrimination by Federal Contractors (DEVIATION) (RFO APR 2026)                                                                                           |
| 52.223-23      | Sustainable Products and Services (DEVIATION) (RFO APR 2026)                                                                                                              |
| 52.226-8       | Encouraging Contractor Policies to Ban Text Messaging While Driving (MAY 2024)                                                                                            |
| 52.229-12      | Tax on Certain Foreign Procurements (APR 2026)                                                                                                                            |
| 52.232-33      | Payment by Electronic Funds Transfer – System for Award Management (OCT 2018)                                                                                             |
| 52.232-40      | Providing Accelerated Payments to Small Business Subcontractors (DEVIATION) (RFO APR 2026)                                                                                |

|                 |                                                                                                    |
|-----------------|----------------------------------------------------------------------------------------------------|
| 52.233-3        | Protest after Award (DEVIATION) (RFO APR 2026)                                                     |
| 52.233-4        | Applicable Law for Breach of Contract Claim (DEVIATION) (RFO APR 2026)                             |
| 52.240-91 Alt I | Security Prohibitions and Exclusions (DEVIATION) (RFO NOV 2025)                                    |
| 52.240-93       | Basic Safeguarding of Covered Contractor Information Systems (DEVIATION) (RFO NOV 2025)            |
| 52.244-6        | Subcontracts for Commercial Products and Commercial Services (Jan 2025) (DEVIATION) (RFO NOV 2025) |
| 52.245-1        | Government Property (SEP 2021)                                                                     |

## 2. Federal Acquisition Regulation (FAR) Clauses Incorporated in Full Text

### **FAR 52.217-8 Option to Extend Services (NOV 1999)**

The Government may require continued performance of any services within the limits and at the rates specified in the contract. These rates may be adjusted only as a result of revisions to prevailing labor rates provided by the Secretary of Labor. The option provision may be exercised more than once, but the total extension of performance hereunder shall not exceed 6 months. The Contracting Officer may exercise the option by written notice to the Contractor within 15 days before the end of the period of performance.

(End of Clause)

### **FAR 52.227-17 Rights in Data-Special Works (DEC 2007)**

(a) *Definitions.* As used in this clause-

*Data* means recorded information, regardless of form or the media on which it may be recorded. The term includes technical data and computer software. The term does not include information incidental to contract administration, such as financial, administrative, cost or pricing, or management information.

*Unlimited rights* means the rights of the Government to use, disclose, reproduce, prepare derivative works, distribute copies to the public, and perform publicly and display publicly, in any manner and for any purpose, and to have or permit others to do so.

(b) *Allocation of Rights.*

(1) The Government shall have-

- (i) Unlimited rights in all data delivered under this contract, and in all data first produced in the performance of this contract, except as provided in paragraph (c) of this clause.
- (ii) The right to limit assertion of copyright in data first produced in the performance of this contract, and to obtain assignment of copyright in that data, in accordance with paragraph (c)(1) of this clause.
- (iii) The right to limit the release and use of certain data in accordance with paragraph (d) of this clause.

(2) The Contractor shall have, to the extent permission is granted in accordance with paragraph (c)(1) of this clause, the right to assert claim to copyright subsisting in data first produced in the performance of this contract.

(c) *Copyright-*

(1) Data first produced in the performance of this contract.

- (i) The Contractor shall not assert or authorize others to assert any claim to copyright subsisting in any data first produced in the performance of this contract without prior written permission of the

Contracting Officer. When copyright is asserted, the Contractor shall affix the appropriate copyright notice of 17 U.S.C. 401 or 402 and acknowledgment of Government sponsorship (including contract number) to the data when delivered to the Government, as well as when the data are published or deposited for registration as a published work in the U.S. Copyright Office. The Contractor grants to the Government, and others acting on its behalf, a paid-up, nonexclusive, irrevocable, worldwide license for all delivered data to reproduce, prepare derivative works, distribute copies to the public, and perform publicly and display publicly, by or on behalf of the Government.

(ii) If the Government desires to obtain copyright in data first produced in the performance of this contract and permission has not been granted as set forth in paragraph (c)(1)(i) of this clause, the Contracting Officer shall direct the Contractor to assign (with or without registration), or obtain the assignment of, the copyright to the Government or its designated assignee.

(2) *Data not first produced in the performance of this contract.* The Contractor shall not, without prior written permission of the Contracting Officer, incorporate in data delivered under this contract any data not first produced in the performance of this contract and that contain the copyright notice of 17 U.S.C. 401 or 402, unless the Contractor identifies such data and grants to the Government, or acquires on its behalf, a license of the same scope as set forth in paragraph (c)(1) of this clause.

(d) *Release and use restrictions.* Except as otherwise specifically provided for in this contract, the Contractor shall not use, release, reproduce, distribute, or publish any data first produced in the performance of this contract, nor authorize others to do so, without written permission of the Contracting Officer.

(e) *Indemnity.* The Contractor shall indemnify the Government and its officers, agents, and employees acting for the Government against any liability, including costs and expenses, incurred as the result of the violation of trade secrets, copyrights, or right of privacy or publicity, arising out of the creation, delivery, publication, or use of any data furnished under this contract; or any libelous or other unlawful matter contained in such data. The provisions of this paragraph do not apply unless the Government provides notice to the Contractor as soon as practicable of any claim or suit, affords the Contractor an opportunity under applicable laws, rules, or regulations to participate in the defense of the claim or suit, and obtains the Contractor's consent to the settlement of any claim or suit other than as required by final decree of a court of competent jurisdiction; and these provisions do not apply to material furnished to the Contractor by the Government and incorporated in data to which this clause applies.

(End of clause)

### **3. Health and Human Services Acquisition Regulation (HHSAR) Clauses Incorporated in Full Text**

#### **HHSAR 352.203-70 Anti-Lobbying (DEVIATION) (JUN 2026)**

Pursuant to the HHS annual appropriations acts, except for normal and recognized executive-legislative relationships, the Contractor must not use any HHS contract funds for:

(a) Publicity or propaganda purposes;

(b) The preparation, distribution, or use of any kit, pamphlet, booklet, publication, electronic communication, radio, television, or video presentation designed to support or defeat the enactment of legislation before the Congress or any State or local legislature or legislative body, except in presentation to the Congress or any state or local legislature itself; or designed to support or defeat any proposed or pending regulation, administrative action, or order issued by the executive branch of any state or local government, except in presentation to the executive branch of any state or local government itself; or

(c) Payment of salary or expenses of the Contractor, or any agent acting for the Contractor, related to any activity designed to influence the enactment of legislation, appropriations, regulation, administrative action, or Executive order proposed or pending before the Congress or any state government, state legislature or local legislature or legislative body, other than for normal and recognized executive-legislative relationships or participation by an agency or officer of a state, local, or tribal government in policymaking and administrative processes within the executive branch of that government.

(d) The prohibitions in paragraphs (a), (b), and (c) above shall of this clause include any activity to advocate or promote any proposed, pending, or future federal, state, or local tax increase, or any proposed, pending, or future requirement for, or restriction on, any legal consumer product, including its sale or marketing, including, but not limited to, the advocacy or promotion of gun control.

(End of clause)

#### **HHSAR 352.204-72 Records Management (DEVIATION) (FEB 2024)**

(a) *Applicability.* This clause applies to contracts that include Federal records, as defined in paragraph (b).

(b) *Definition.* As used in this clause—

*Federal record* means all recorded information, regardless of form or characteristics, made or received by a Federal agency under Federal law or in connection with the transaction of public business and preserved or appropriate for preservation by that agency or its legitimate successor as evidence of the organization, functions, policies, decisions, procedures, operations, or other activities of the United States Government or because of the informational value of data in them. See 44 U.S.C. 3301.

(1) The term Federal record—

(i) Includes HHS records;

(ii) Does not include personal materials;

(iii) Applies to records created, received, or maintained by Contractors pursuant to their contract; and

(iv) May include deliverables and documentation associated with deliverables.

(2) *Recorded information* means all traditional forms of records, regardless of physical form or characteristics, including information created, manipulated, communicated, or stored in digital or electronic form. (See 44 U.S.C. 3301.)

(3) *Personal materials* means documentary materials belonging to an individual that are not used to conduct agency business. Personal files are excluded from the definition of Federal records and are not owned by the Government. (See 36 CFR 1220.18.)

(c) *Requirements.*

(1) The Contractor shall comply with all applicable records management laws and regulations, as well as National Archives and Records Administration (NARA) records policies, including

but not limited to the Federal Records Act (44 U.S.C. chapters 21, 29, 31, 33), NARA regulations at 36 CFR chapter XII subchapter B, and those policies associated with the safeguarding of records covered by the Privacy Act of 1974 (5 U.S.C. 552a). These policies include the preservation of all Federal records, regardless of form or characteristics, mode of transmission, or state of completion.

(2) In accordance with 36 CFR 1222.32, all data created for Government use and delivered to, or falling under the legal control of, the Government are Federal records subject to the provisions of 44 U.S.C. chapters 21, 29, 31, and 33, the Freedom of Information Act (FOIA) (5 U.S.C. 552), and the Privacy Act of 1974 (5 U.S.C. 552a), and must be managed and scheduled for disposition only as permitted by statute or regulation.

(3) In accordance with 36 CFR 1222.32, the Contractor shall maintain all Federal records created for Government use or created in the course of performing the contract and/or delivered to, or under the legal control of the Government and must be managed in accordance with Federal law. Electronic records and associated metadata must be accompanied by sufficient technical documentation to permit understanding and use of the records and data.

(4) The Contractor is responsible for preventing the alienation or unauthorized destruction of Federal records, including all forms of mutilation. Federal records may not be removed from the legal custody of HHS or destroyed except for in accordance with the provisions of the agency records schedules and with the written concurrence of the Contracting Officer. Willful and unlawful destruction, damage or alienation of Federal records is subject to the fines and penalties imposed by 18 U.S.C. 2701. The Contractor shall report to the Contracting Officer any unlawful or accidental removal, defacing, alteration, or destruction of Federal records.

(5) The Contractor shall immediately notify the Contracting Officer upon discovery of any inadvertent or unauthorized disclosures of information, data, documentary materials, records or equipment. Disclosure of non-public information is limited to authorized personnel with a need-to-know as described in the contract. The Contractor shall ensure that appropriate personnel are trained to adhere to these contract requirements, and that applicable, administrative, technical, and physical safeguards are established to ensure the security and confidentiality of information, data, documentary material, Federal records and/or equipment is properly protected. The Contractor shall not remove Federal Records from Government facilities or systems, or facilities or systems operated or maintained on the Government's behalf, without the express written permission of the Contracting Officer. When information, data, documentary material, Federal records and/or equipment are no longer required, it shall be returned to HHS control or the Contractor must hold it until otherwise directed. Items returned to the Government shall be hand carried, mailed, emailed, or securely electronically transmitted to the Contracting Officer or as otherwise directed by the Contracting Officer. Destruction of Federal records is expressly prohibited unless in accordance with paragraph (c)(4).

(6) The Contractor shall only use Government information technology equipment for purposes specifically authorized by the contract and in accordance with HHS policy.

(7) The Contractor shall not create or maintain any Federal records containing any non-public HHS information that are not specifically authorized by the contract.

(8) The Contractor shall not retain, use, sell, or disseminate copies of any deliverable that contains information covered by the Privacy Act of 1974 or that which is generally protected from public disclosure by an exemption to the Freedom of Information Act.

(9) All Contractor employees assigned to this contract handle Federal records are required to take HHS-provided records management training. The Contractor is responsible for confirming training has been completed according to agency policies, including initial training and any annual or refresher training.

(d) *Subcontract flowdown*. The Contractor shall incorporate the substance of this clause, its terms and requirements including this paragraph, in all subcontracts under this contract.

(End of clause)

#### **HHSAR 352.208-70 Printing and Duplication (DEVIATION) (FEB 2026)**

- (a) Unless otherwise specified in this contract, no printing by the Contractor or any subcontractor is authorized under this contract. All printing required must be performed by the Government Printing Office except as authorized by the Contracting Officer. The Contractor must submit camera-ready copies to the Contracting Officer's Representative (COR). The terms "printing" and "duplicating/copying" are defined in the Government Printing and Binding Regulations of the Joint Committee on Printing.
- (b) If necessary for performance of the contract, the Contractor may duplicate or copy less than 5,000 production units of only one page, or less than 25,000 production units in aggregate of multiple pages for the use of a department or agency. A production unit is defined as one sheet, size 8.5 x 11 inches, one side only, and one color. The pages may not exceed a maximum image size of 10 3/4 by 14 1/4 inches. This page limit applies to each printing requirement and not for all printing requirements under the entire contract.
- (c) Approval for all printing, as well as duplicating/copying in excess of the stated limits, must be obtained from the COR who will consult with the designated publishing services office and provide direction to the contractor. The cost of any unauthorized printing or duplicating/copying under this contract will be considered an unallowable cost for which the Contractor will not be reimbursed.

(End of clause)

#### **HHSAR 352.211-3 Paperwork Reduction Act (DEVIATION)(NOV 2025)**

- (a) This contract involves a requirement to collect or record information calling either for answers to identical questions from 10 or more persons other than Federal employees, or information from Federal employees which is outside the scope of their employment, for use by the Federal government or disclosure to third parties; therefore, the Paperwork Reduction Act of 1995 (44 U.S.C. 3501 et seq.) must apply to this contract. No plan, questionnaire, interview guide or other similar device for collecting information (whether repetitive or single time) may be used without the Office of Management and Budget (OMB) first providing clearance. Contractors and the Contracting Officer's Representative must be guided by the provisions of 5 CFR part 1320, Controlling Paperwork Burdens on the Public, and seek the advice of the HHS operating division or Office of the Secretary Reports Clearance Officer to determine the procedures for acquiring OMB clearance.
- (b) The Contractor must not expend any funds or begin any data collection until the Contracting Officer provides the Contractor with written notification authorizing the expenditure of funds and the collection of data. The Contractor must allow at least 120 days for OMB clearance. The Contracting Officer will



consider excessive delays caused by the Government which arise out of causes beyond the control and without the fault or negligence of the Contractor in accordance with the Excusable Delays or Default clause of this contract.

(End of clause)

#### **HHSAR 352.232-71 Electronic Submission of Payment Requests (DEVIATION)(APR 2026)**

(a) *Definitions.* As used in this clause –

*Payment request* means a bill, voucher, invoice, or request for contract financing payment with associated supporting documentation. The payment request must comply with the requirements in FAR 32.905(b) and the applicable payment clause included in this contract.

(b) *Submission instructions.* Except as provided in paragraph (c) of this clause, the Contractor must submit payment requests electronically using the Department of Treasury Invoice Processing Platform (IPP) or successor system. Information regarding IPP, including IPP Customer Support contact information, is available at [www.ipp.gov](http://www.ipp.gov) or any successor site.

(c) *Alternate submission procedures.* The Contractor may submit payment requests using other than IPP only when the Contracting Officer authorizes alternate procedures in writing.

(d) *Submission of alternate payment procedures authorization.* If alternate payment procedures are authorized, the Contractor must include a copy of the Contracting Officer's written authorization with each payment request.

(End of clause)

#### **HHSAR 352.237-75 Key Personnel (DEC 2015)**

The key personnel specified in this contract are considered to be essential to work performance. At least 30 days prior to the contractor voluntarily diverting any of the specified individuals to other programs or contracts the Contractor shall notify the Contracting Officer and shall submit a justification for the diversion or replacement and a request to replace the individual. The request must identify the proposed replacement and provide an explanation of how the replacement's skills, experience, and credentials meet or exceed the requirements of the contract (including, when applicable, Human Subjects Testing requirements). If the employee of the contractor is terminated for cause or separates from the contractor voluntarily with less than thirty days notice, the Contractor shall provide the maximum notice practicable under the circumstances. The Contractor shall not divert, replace, or announce any such change to key personnel without the written consent of the Contracting Officer. The contract will be modified to add or delete key personnel as necessary to reflect the agreement of the parties.

(End of clause)

#### **HHSAR 352.239-79 Electronic, Information, and Communication Technology Accessibility (DEVIATION) (FEB 2024)**

(a) Pursuant to Section 508 of the Rehabilitation Act of 1973 (29 U.S.C. 794d), as amended by the Workforce Investment Act of 1998, all information and communication technology (ICT) supplies,

products, platforms, information, documentation, and services, or support developed, acquired, maintained or delivered under this contract or order must comply with the Revised 508 Standards, which are located at 36 C.F.R. 1194.1 and Appendices A, B, and C, and are available at <https://www.access-board.gov/ict/>. Information about Section 508 is available at <https://www.hhs.gov/web/section-508/index.html>.

(b) Additional Section 508 accessibility standards applicable to this contract or order are identified in the Performance Work Statement.

If it is determined by the Government that ICT supplies, products, platforms, information, documentation, and services support provided by the Contractor do not conform to the described accessibility standards in the contract, remediation of the supplies, products, platforms, information, documentation, or services support to the level of conformance specified in the contract will be the responsibility of the Contractor at its own expense.

(c) In the event of a modification(s) to this contract or order, which adds new ICT supplies or services or revises the type of, or specifications for, supplies, products, platforms, information, documentation, or services support, the Contracting Officer shall require that the Contractor submit a completed HHS Section 508 Accessibility Conformance Checklist (see <https://www.hhs.gov/web/section-508/accessibility-checklists/index.html>) or an Accessibility Conformance Report (ACR) (based on the Voluntary Product Accessibility Template (VPAT) see <https://www.itic.org/policy/accessibility/vpat> and any other additional information necessary to assist the Government in determining that the ICT supplies or services conform to Section 508 accessibility standards. If it is determined by the Government that ICT supplies, products, platforms, information, documentation, and services support provided by the Contractor do not conform to the described accessibility standards in the contract, remediation of the supplies, products, platforms, information, documentation, or services support to the level of conformance specified in the contract will be the responsibility of the Contractor at its own expense.

(d) If this is an Indefinite-Delivery type contract, a Blanket Purchase Agreement or a Basic Ordering Agreement, the task/delivery order requests that include ICT supplies, products, platforms, information, documentation, or services support will define the specifications and accessibility standards for the order. In those cases, the Contractor shall be required to provide a completed HHS Section 508 Accessibility Conformance Checklist (see <https://www.hhs.gov/web/section-508/accessibility-checklists/index.html>) or an ACR (based on the VPAT see <https://www.itic.org/policy/accessibility/vpat> and any other additional information necessary to assist the Government in determining that the ICT supplies, products, platforms, information, documentation, or services support conform to Section 508 accessibility standards. If it is determined by the Government that ICT supplies and services provided by the Contractor do not conform to the described accessibility standards in the provided documentation, remediation of the supplies, products, platforms, information, documentation, or services support to the level of conformance specified in the contract will be the responsibility of the Contractor at its own expense.

(e) The contractor shall identify to the Contracting Officer any perceived exception or exemption to Section 508 requirements for review by the agency Section 508 Program.

(End of clause)

#### **4. CDC Local Terms and Conditions**

##### **CDCG.02 Contracting Officers Representative (COR) (JUL 2017)**

Performance of the work hereunder shall be subject to the technical directions of the designated COR for this contract. As used herein, technical directions are directions to the Contractor which fill in details, suggests possible lines of inquiry, or otherwise completes the general scope of work set forth herein. These technical directions must be within the general scope of work, and may not alter the scope of work or cause changes of such a nature as to justify an adjustment in the stated contract price/cost, or any stated limitation thereof.

In the event that the Contractor believes full implementation of any of these directions may exceed the scope of the contract, he or she shall notify the originator of the technical direction and the Contracting Officer, immediately or as soon as possible, in a letter or e-mail separate of any required report(s). No technical direction, nor its fulfillment, shall alter or abrogate the rights and obligations fixed in this contract.

The Government COR is not authorized to change any of the terms and conditions of this contract. Contract changes shall be made only by the Contracting Officer by properly written modification(s) to the contract.

The Government will provide the Contractor with a copy of the COR delegation memorandum upon request.

##### **CDCG.03 Contracting Officer (JUL 1999)**

(a) The Contracting Officer is the only individual who can legally commit the Government to the expenditure of public funds. No person other than the Contracting Officer can make any changes to the terms, conditions, general provisions, or other stipulations of this contract.

(b) No information, other than that which may be contained in an authorized modification to this contract, duly issued by the Contracting Officer, which may be received from any person employed by the United States Government, or otherwise, shall be considered grounds for deviation from any stipulation of this contract.

##### **CDC G.07 Payment by Electronic Funds Transfer (JAN 2026)**

(a) The Government shall use electronic funds transfer to the maximum extent possible when making payments under this contract. FAR 52.232-33, Payment by Electronic Funds Transfer –System for Award Management, requires the contractor to designate in writing a financial institution for receipt of electronic funds transfer payments.

(b) In the case that EFT information is not within the System of Award Management, FAR 52.232-34, Payment by Electronic Funds Transfer-Other than System for Award Management, requires mandatory submission of Contractor's EFT information directly to the office designated in this contract to receive that information (hereafter: "designated office"); see below. The contractor shall submit the EFT information within the form titled "ACH Vendor/Miscellaneous Payment Enrollment Form" to the address indicated below. Note: The form is either attached to this contract (see Section J, List of Attachments) or may be obtained from the CDC Office of Financial Resources at 678-475-4500 or [cpbapinv@cdc.gov](mailto:cpbapinv@cdc.gov).

- (c) In cases where the contractor has previously provided such information, i.e., pursuant to a prior contract/order, and been enrolled in the program, the form is not required unless the designated financial institution has changed.
- (d) The completed form shall be mailed or sent via facsimile after award, but no later than 15 calendar days before an invoice is submitted, to the following address:

The Centers for Disease Control and Prevention  
Office of Financial Resources  
P.O. Box 15880  
Atlanta, GA 30333

#### **CDCH.04 Key Personnel (Jan 2026)**

The key personnel cited below are considered essential to the work performed under the contract. Pursuant to the terms of HHSAR Clause 352.237-75, Key Personnel, the Contractor shall not replace or divert any of these individuals without the written consent of the Contracting Officer.

| Personnel | Title |
|-----------|-------|
|           |       |
|           |       |
|           |       |

#### **CDCH.08 Smoke Free Working Environment (MAY 2009)**

In compliance with Department of Health and Human Services (DHHS) regulations, all contractor personnel performing work within CDC/ATSDR facilities shall observe the CDC/ATSDR smoke-free working environment policy at all times. This policy prohibits smoking in all CDC/ATSDR buildings and in front of buildings which are open to the public. This policy is also applicable to contractor personnel who do not work full-time within CDC/ATSDR facilities, but are attending meetings within CDC/ATSDR facilities.

#### **CDCH.10 Artificial Intelligence Compliance and Risk Management Plan (MAY 2026)**

The use of Artificial Intelligence (AI), including GenAI, is prohibited without an approved AI Compliance and Risk Management Plan. The contractor is responsible for updating the AI Compliance and Risk Management Plan throughout the life of the contract as changes occur. If a change to AI use, AI functionality, AI model, or deployment configuration is anticipated, the contractor must notify the contracting officer and Contracting Officer's Representative (COR) immediately and provide a revised plan. The government will issue approval or disapproval before AI can be incorporated. The offeror must identify whether the planned or potential AI use may involve a high-impact AI use case (as defined in defined in Appendix A of OMB-M-25-21) and must provide sufficient descriptive information for the Government to complete any required AI impact or high-impact assessment.

The AI Compliance and Risk Management Plan must:

1. Identify the specific tasks or functions where AI will be used.

2. Explain how logs, audits, or other forms of AI generated data will be stored, used, retained, or deleted.
3. State whether the AI technologies are open-source, proprietary, or any other type.
4. Include applicable model cards or system documentation describing the AI technologies used.
5. Describe how bias in AI models and outputs will be identified, monitored, and mitigated, including the origin, quality, and weighting of data.
6. Explain the AI safeguards in place, including compliance and risk management practices, protections against unauthorized data access, and steps taken to manage bias and reduce risk in alignment with applicable AI policies and directives.
7. Describe internal policies governing AI use, including transparency, accountability, data integrity, accuracy, protection of sensitive or proprietary information, foreseeable risks, and potential social impacts.
8. Explain how the contractor will assess and prevent unfair or disparate impacts, address privacy, civil rights, and civil liberties concerns, and prevent misuse, unauthorized use, or corruption of AI systems.
9. Confirm that the AI solution will not make or support decisions based on unlawful discrimination in violation of federal civil rights laws, including Title VII of the Civil Rights Act, the Americans with Disabilities Act (ADA), and the Age Discrimination in Employment Act (ADEA).
10. Describe how applicable technological or voluntary consensus standards will be incorporated to reduce acquisition and operational risk
1. The plan must describe how Government data, outputs, prompts, logs, and outputs be accessed, used, protected, retained, deleted, and transferred, and identify any proposed limitations on Government rights, access, or reuse.

The AI Compliance and Risk Management Plan will be reviewed by the Government and an approval or disapproval issued.

### **CDCH.13 Government Property (JUL 2017)**

- (a) Government-Furnished Property (GFP). In accordance with the terms of FAR 52.245-1, Government Property, the Government reserves the right to supply the Contractor, as Government-furnished property, any additional supplies, equipment, and materials determined by the Contracting Officer to be necessary and in the best interest of the Government.
- (b) Contractor-Acquired Property (CAP). The Contractor must receive written consent from the Contracting Officer prior to purchase of any CAP not expressly identified in the contract, and as defined in FAR 52.245-1.
- (c) Accountable and Sensitive Government Property. The Government will provide property labels and other identification for contractor-acquired Government property that is considered Accountable as defined in the [HHS Logistics Management Manual](#) (LMM) or considered Sensitive as defined in [CDC's Sensitive Items List \(http://intranet.cdc.gov/ofr/documents/contracts/Authorized-Prohibited-List.pdf\)](http://intranet.cdc.gov/ofr/documents/contracts/Authorized-Prohibited-List.pdf)
- (d) The contractor shall be responsible for the control and accountable record keeping of any Government property used in the performance of this contract predominately outside the confines of a Government controlled workspace in accordance with the HHS Contracting Guide found on the [OSSAM Government Property and Contractors Property intranet page](#).
- (e) The Chief of the Office of Safety, Security and Asset Management (OSSAM), Asset Management Services Office, Centers for Disease Control and Prevention (CDC), is hereby designated as the

Property Administrator for this contract. The Contractor shall identify each item of equipment furnished by the Government to the Contractor or acquired by the Contractor using contract funds, with a suitable decal, tag, or other marking, as prescribed by the Property Administrator, and shall follow the guidance set forth in the [HHS Contracting Guide for Contract of Government Property](#).

Contractors may request copies of documents referenced above from the Contracting Officer if unable to access the links.

## **CDCH.14 Records Management Obligations (JUN 2020)**

### *A. Applicability*

The following applies to all Contractors whose employees create, work with, or otherwise handle Federal records, as defined in Section B, regardless of the medium in which the record exists.

### *B. Definitions*

“Federal record” as defined in 44 U.S.C. § 3301, includes all recorded information, regardless of form or characteristics, made or received by a Federal agency under Federal law or in connection with the transaction of public business and preserved or appropriate for preservation by that agency or its legitimate successor as evidence of the organization, functions, policies, decisions, procedures, operations, or other activities of the United States Government or because of the informational value of data in them.

The term Federal record:

1. includes Centers for Disease Control and Prevention (CDC) records.
2. does not include personal materials.
3. applies to records created, received, or maintained by Contractors pursuant to their CDC contract.
4. may include deliverables and documentation associated with deliverables.

### *C. Requirements*

1. Contractor shall comply with all applicable records management laws and regulations, as well as National Archives and Records Administration (NARA) records policies, including but not limited to the Federal Records Act (44 U.S.C. chs. 21, 29, 31, 33), NARA regulations at 36 CFR Chapter XII Subchapter B, and those policies associated with the safeguarding of records covered by the Privacy Act of 1974 (5 U.S.C. 552a). These policies include the preservation of all records, regardless of form or characteristics, mode of transmission, or state of completion.
2. In accordance with 36 CFR 1222.32, all data created for Government use and delivered to, or falling under the legal control of, the Government are Federal records subject to the provisions of 44 U.S.C. chapters 21, 29, 31, and 33, the Freedom of Information Act (FOIA) (5 U.S.C. 552), as amended, and the Privacy Act of 1974 (5 U.S.C. 552a), as amended and must be managed and scheduled for disposition only as permitted by statute or regulation.
3. In accordance with 36 CFR 1222.32, Contractor shall maintain all records created for Government use or created in the course of performing the contract and/or delivered to, or under the legal control of the Government and must be managed in accordance with Federal law. Electronic records and associated metadata must be accompanied by sufficient technical documentation to permit understanding and use of the records and data.
4. CDC and its contractors are responsible for preventing the alienation or unauthorized destruction of records, including all forms of mutilation. Records may not be removed from the legal custody of CDC or destroyed except for in accordance with the provisions of the agency records schedules and with the written concurrence of the Head of the Contracting Activity. Willful and unlawful destruction, damage or alienation of Federal records is subject to the fines and penalties imposed by 18 U.S.C. 2701. In the event of any unlawful or accidental removal, defacing, alteration, or destruction of records, Contractor must report to the Contracting Officer and the

Contracting Officer's Representative. The agency must report promptly to NARA in accordance with 36 CFR 1230.

5. The Contractor shall immediately notify the appropriate Contracting Officer upon discovery of any inadvertent or unauthorized disclosures of information, data, documentary materials, records or equipment. Disclosure of non-public information is limited to authorized personnel with a need-to-know as described in the contract. The Contractor shall ensure that the appropriate personnel, administrative, technical, and physical safeguards are established to ensure the security and confidentiality of this information, data, documentary material, records and/or equipment is properly protected. The Contractor shall not remove material from Government facilities or systems, or facilities or systems operated or maintained on the Government's behalf, without the express written permission of the Head of the Contracting Activity. When information, data, documentary material, records and/or equipment is no longer required, it shall be returned to CDC control or the Contractor must hold it until otherwise directed. Items returned to the Government shall be hand carried, mailed, emailed, or securely electronically transmitted to the Contracting Officer or address prescribed in the contract. Destruction of records is EXPRESSLY PROHIBITED unless in accordance with Paragraph (4).
6. The Contractor is required to obtain the Contracting Officer's approval prior to engaging in any contractual relationship (sub-contractor) in support of this contract requiring the disclosure of information, documentary material and/or records generated under, or relating to, contracts. The Contractor (and any sub-contractor) is required to abide by Government and CDC guidance for protecting sensitive, proprietary information, classified, and controlled unclassified information.
7. The Contractor shall only use Government IT equipment for purposes specifically tied to or authorized by the contract and in accordance with CDC policy.
8. The Contractor shall not create or maintain any records containing any non-public CDC information that are not specifically tied to or authorized by the contract.
9. The Contractor shall not retain, use, sell, or disseminate copies of any deliverable that contains information covered by the Privacy Act of 1974 or that which is generally protected from public disclosure by an exemption to the Freedom of Information Act.
10. Training. All Contractor employees assigned to this contract who create, work with, or otherwise handle records are required to take CDC-provided records management training. The Contractor is responsible for confirming training has been completed according to agency policies, including initial training and any annual or refresher training.

*D. Flowdown of requirements to subcontractors*

1. The Contractor shall incorporate the entire substance of the terms and conditions herein, including this paragraph, in all subcontracts under this contract, and must require written subcontractor acknowledgment of same.
2. Violation by a subcontractor of any provision set forth herein will be attributed to the Contractor.

**CDCH.16 Non-Disclosure Agreement for Contractor and Contractor Employees (JUN 2020)**

- (a) The contractor and contractor employees shall prepare and submit Non-Disclosure Agreements (NDA) to the Contracting Officer prior to access of government information or the commencement of work at CDC.
- (b) The NDAs, at Exhibit I and II, are required in service contracts where contractor's employees will have access to non-public and procurement-sensitive information while performing functions in support of the Government. The NDA also requires contractor's employees properly identify themselves as employees of a contractor when communicating or interacting with CDC employees, employees of other governmental entities, and members of the public (when communication or interaction relates to the contractor's work with the CDC). The Federal Acquisition Regulation

(FAR) 37.114 (c), states “All contractor personnel attending meetings, answering Government telephones, and working in other situations where their contractor status is not obvious to third parties are required to identify themselves as such to avoid creating an impression in the minds of members of the public or Congress that they are Government officials, unless, in the judgment of the agency, no harm can come from failing to identify themselves. They must also ensure that all documents or reports produced by contractors are suitably marked as contractor products or that contractor participation is appropriately disclosed.”

- (c) The contractor shall inform contractor employees of the identification requirements by which they must abide and monitor employee compliance with the identification requirements.
- (d) During the contract performance period, the contractor is responsible to ensure that all additional or replacement contractors’ employees sign an NDA and it is submitted to the Contracting Officer prior to commencement of their work with the CDC.
- (e) Contractor employees in designated positions or functions that have not signed the appropriate NDA shall not have access to any non-public, procurement sensitive information or participate in government meetings where sensitive information may be discussed.
- (f) The Contractor shall prepare and maintain a current list of employees working under NDAs and submit to the Contracting Officer upon request during the contract period of performance. The list should at a minimum include: contract number, employee’s name, position, date of hire and NDA requirement.



**EXHIBIT I****Centers for Disease Control and Prevention (CDC)  
Contractor Non-Disclosure Agreement****I. Non-public Information**

[Name of contractor] understands that in order to fulfill the responsibilities pursuant to [contract name and number] between the Centers for Disease Control and Prevention and [Name of CDC contractor] dated [date], employees of [contractor] will have access to non-public information, including confidential and privileged information contained in government-owned information technology systems. For purposes of this agreement, confidential information means government information that is not or will not be generally available to the public. Privileged information means information which cannot be disclosed without the prior written consent of the CDC.

In order to properly safeguard non-public information, [contractor] agrees to ensure that prior to being granted access to government information or the commencement of work for the CDC, whichever is applicable, all contractor employees will sign a Non-Disclosure Agreement (NDA) provided by the CDC prior to beginning work for the CDC. Contractor agrees to submit to the Contracting Officer the original signed copies of NDAs signed by the contractor's employees in accordance with the instructions provided by the Contracting Officer. Failure to provide signed NDAs in accordance with this agreement and instructions provided by the Contracting Officer could delay or prevent the employee from commencing or continuing work at the CDC until such agreement is signed and returned to the Contracting Officer.

Contractor further agrees that it will not cause or encourage any employee to disclose, publish, divulge, release, or make known in any manner or to any extent, to any individual other than an authorized Government employee any non-public information that the employee may obtain in connection with the performance of the employee's responsibilities to the CDC.

**II. Procurement-Sensitive Information**

Contractor further agrees that it will not cause or encourage any employee to disclose, publish, divulge, release, or make known in any manner or to any extent, to any individual, other than an authorized Government employee, any procurement-sensitive information gained while in connection with fulfilling the employee's responsibilities at the CDC. For purposes of this agreement, procurement-sensitive information includes, but is not limited to, all information in Statements of Work (SOW), Procurement Requests (PR), and Requests for Proposal (RFP); Responses to RFPs, including proposals, questions from potential offerors; non-public information regarding procurements; all documents, conversations, discussions, data, correspondence, electronic mail (e-mail), presentations, or any other written or verbal communications relating to, concerning, or affecting proposed or pending solicitations or awards; procurement data; contract information plans; strategies; source selection information and documentation; offerors' identities; technical and cost data; the identity of government personnel involved in the solicitation; the schedule of key technical and procurement events in the award determination process; and any other information that may provide an unfair competitive advantage to a contractor or potential contractor if improperly disclosed to them, or any of their employees.

Contractor understands and agrees that employee access to any procurement-sensitive information may create a conflict of interest which will preclude contractor from becoming a competitor for any acquisition(s) resulting from this information. Therefore, if an employee participates in any discussions relating to procurement-sensitive information, assists in developing any procurement-sensitive information, or otherwise obtains any procurement-sensitive information while performing duties at the

CDC, contractor understands and agrees that contractor may be excluded from competing for any acquisition(s) resulting from this information.

### III. Identification of Non-Government Employees

Contractor understands that its employees are not agents of the Government. Therefore, unless otherwise directed in writing by the CDC, contractor agrees to assist and monitor employee compliance with the following identification procedures:

- A. At the beginning of interactions with CDC employees, employees of other governmental entities, and members of the public (when such communication or interaction relates to the contractor's work with the CDC), contractors' employees will identify themselves as an employee of a contractor.
- B. Contractors' employees will include the following disclosures in all written communications, including outgoing electronic mail (e-mail) messages, in connection with contractual duties to the CDC:

*Employee's name*  
*Name of contractor*  
*Center or office affiliation*  
Centers for Disease Control and Prevention

- C. At the beginning of telephone conversations or conference calls, contractors' employees will identify themselves as an employee of a contractor.
- D. Contractors' employees should not wear any CDC logo on clothing, except for a CDC issued security badge while carrying out work for CDC or on CDC premises. The only other exception is when a CDC management official has granted permission to use the CDC logo.
- E. Contractors' employees will program CDC voice mail message to identify themselves as an employee of a contractor.

I understand that federal laws including, 18 U.S.C. 641 and 18 U.S.C. 2071, provide criminal penalties for, among other things, unlawfully removing, destroying or converting to personal use, or use of another, any public records. Contractor acknowledges that contractor has read and fully understands this agreement.

Name of contractor: \_\_\_\_\_

Signature of Authorized Representative of Contractor: \_\_\_\_\_

Date: \_\_\_\_\_

Copies retained by: Contracting Officer and contractor

## EXHIBIT II

### Centers for Disease Control and Prevention (CDC) Contractors' Employee Non-Disclosure Agreement

#### **I. Non-Public Information**

I understand that in order to fulfill my responsibilities as an employee of **[Name of CDC contractor]**, I will have access to non-public information, including confidential and privileged information contained in government-owned information technology systems. For purposes of this agreement, confidential information means government information that is not or will not be generally available to the public. Privileged information means information which cannot be disclosed without the prior written consent of the CDC.

I, **[Name of Employee]**, agree to use non-public information only in performance of my responsibilities to the CDC. I agree further that I will not disclose, publish, divulge, release, or make known in any manner or to any extent, to any individual other than an authorized Government employee, any non-public information that I may obtain in connection with the performance of my responsibilities to the CDC.

#### **II. Procurement-Sensitive Information**

I further agree that unless I have prior written permission from the CDC, I will not disclose, publish, divulge, release, or make known in any manner or to any extent, to any individual other than an authorized Government employee, any procurement-sensitive information gained in connection with the performance of my responsibilities to the CDC. I specifically agree not to disclose any non-public, procurement-sensitive information to employees of my company or any other organization unless so authorized in writing by the CDC. For purposes of this agreement, procurement-sensitive information includes, but is not limited to, all information in Statements of Work (SOW), Procurement Requests (PR), and Requests for Proposal (RFP); Responses to RFPs, including proposals, questions from potential offerors; non-public information regarding procurements; all documents, conversations, discussions, data, correspondence, electronic mail (e-mail), presentations, or any other written or verbal communications relating to, concerning, or affecting proposed or pending solicitations or awards; procurement data; contract information plans; strategies; source selection information and documentation; offerors' identities; technical and cost data; the identity of government personnel involved in the acquisition; the schedule of key technical and procurement events in the award determination process; and any other information that may provide an unfair competitive advantage to a contractor or potential contractor if improperly disclosed to them, or any of their employees.

I understand and agree that my access to any procurement-sensitive information may create a conflict of interest which will preclude me, my current employer, or a future employer from becoming a competitor for any resulting government acquisition derived from this information. Therefore, if I participate in any discussions relating to procurement-sensitive information, assist in developing any procurement-sensitive information, or otherwise obtain any procurement-sensitive information while performing my duties at the CDC, I understand and agree that I, my current employer, and any future employer(s) may be excluded from competing for any resulting acquisitions.

### III. Special Non-Disclosure Agreement for Contractors with Access to CDC Grants Management and Procurement-Related Information Technology Systems

In addition to complying with the non-disclosure requirements and safeguards stated above, I understand that my authorization to use CDC's grants management and procurement systems is strictly limited to the access and functions necessary for the performance of my responsibilities to the CDC and which have been approved in advance by the CDC. I understand that I am not authorized to enter procurement requests for any requirements pertaining to contracts or subcontracts held by me or my employer.

### IV. Identification as a Non-Government Employee

I understand that as an employee of a government contractor, I represent an independent organization and I am not an agent of the Government. Therefore, I agree that unless I have prior written authorization from the CDC, I will, at the beginning of interactions with CDC employees, employees of other governmental entities, members of the public (when such communication or interaction relates to the contractor's work with the CDC), identify myself as an employee of a contractor. I further agree to use the following identification procedures in connection with my work at the CDC:

A. I will include the following disclosures in all written communications, including outgoing electronic mail (e-mail) messages:

*Employee's name*  
*Name of contractor*  
*Center or office affiliation*  
 Centers for Disease Control and Prevention

B. I will identify myself as an employee of a contractor at the beginning of telephone conversations or conference calls;

C. I will not wear any CDC logo on clothing, except for a CDC issued security badge while carrying out work for CDC or on CDC premises; the only other exception is when a CDC management official has granted permission to use the CDC logo.

D. I will program my CDC voice mail message to identify myself as a contractors' employee.

I understand that federal laws including, 18 U.S.C. 641 and 18 U.S.C. 2071, provide criminal penalties for, among other things, unlawfully removing, destroying or converting to personal use, or use of another, any public records. I acknowledge that I have read and fully understand this agreement.

Name of contractor: \_\_\_\_\_

Name of Employee: \_\_\_\_\_

Signature of Employee: \_\_\_\_\_

Date: \_\_\_\_\_

Copies retained by: Contracting Officer, contractor, and Contractor Employee

**CDCH.20 Non-Personal Services (JUN 2020)**

(a) Personal services shall not be performed under this contract. Although the Government may provide sporadic or occasional instructions within the scope of the contract, the Contractor is responsible for control and supervision of its employees. If the Contractor (including its employees) believes any Government action or communication has been given that would create a personal services relationship between the Government and any Contractor employee, the Contractor shall promptly notify the Contracting Officer of this communication or action.

(b) The contractor shall comply with, and ensure their employees and subcontractors comply with, CDC Policy titled "Contractor Identification and Safeguarding of Non-Public Information". No Contractor employee shall hold him or herself out to be a Government employee, agent, or representative. No Contractor employee shall state orally or in writing at any time that he or she is acting on behalf of the Government. In all communications with third parties in connection with this contract, Contractor employees shall identify themselves as Contractor employees and specify the name of the company for which they work. The contractor is limited to performing the services identified in the contract statement of work and shall not interpret any communication with anyone as a permissible change in contract scope or as authorization to perform work not described in the contract. All contract changes will be incorporated by a modification signed by the Contracting Officer.

(c) The Contractor shall ensure that all of its employees and subcontractor employees working on this contract are informed of the terms and conditions herein. The Contractor agrees that this is a non-personal services contract; and that for all the purposes of the contract, the Contractor is not, nor shall it hold itself out to be an agent or partner of, or joint venture with, the Government. The Contractor shall notify its employees that they shall neither supervise nor accept supervision from Government employees. The substance of the terms herein shall be included in all subcontracts at any tier.

(d) The terms and conditions above do not limit the Government's rights under other terms of the contract, including those related to the Government's right to inspect and accept or reject the services performed under this contract.

**CDCH.23 Evaluation of Contractor Performance Utilizing CPARS (APR 2026)**

In accordance with FAR 42.11, Centers for Disease Control and Prevention (CDC) will review and evaluate contract performance. FAR 42.802 and 42.1102 requires agencies to prepare evaluations of contractor performance and submit them to the Contractor Performance Assessment Reporting System (CPARS). CDC utilizes this web-based system to prepare and report contractor performance evaluations. All information contained in these assessments may be used by the Government, within the limitations of FAR 42.11, for future source selections in accordance with FAR 15.104 where past performance is an evaluation factor.

The CPARS system requires a contractor representative to be assigned so that the contractor has appropriate input into the performance evaluation process. The CPARS contractor representative will be given access to CPARS and will be given the opportunity to concur or not-concur with performance evaluations before the evaluations are complete. The CPARS contractor representative will also have the opportunity to add comments to performance evaluations.

The assessment is not subject to the Disputes clause of the contract, nor is it subject to appeal beyond the review and comment procedures described in the guides on the CPARS website. Refer to: [www.cpars.gov](http://www.cpars.gov) for details and additional information related to CPARS, CPARS user access, how contract performance assessments are conducted, and how contractors participate. Access and training for all persons

responsible for the preparation and review of performance assessments is also available at the CPARS website.

The contractor must provide the CDC contracting office with the name, e-mail address, and phone number of their designated CPARS representative who will be responsible for logging into CPARS and reviewing and commenting on performance evaluations. The contractor must maintain a current representative to serve as the contractor representative in CPARS. It is the contractor's responsibility to notify the CDC contracting office, in writing (letter or email), when their CPARS representative information needs to be changed or updated. Failure to maintain current CPARS contractor representative information will result in the loss of an opportunity to review and comment on performance evaluations.

## Section E – Solicitation Terms and Conditions

### 1. FAR 52.252-1 Solicitation Provisions Incorporated by Reference (FEB 1998)

This solicitation incorporates one or more solicitation provisions by reference, with the same force and effect as if they were given in full text. Upon request, the Contracting Officer will make their full text available. The Offeror is cautioned that the listed provisions may include blocks that must be completed by the Offeror and submitted with its quotation or offer. In lieu of submitting the full text of those provisions, the Offeror may identify the provision by paragraph identifier and provide the appropriate information with its quotation or offer. Also, the full text of a solicitation provision may be accessed electronically at this/these address(es):

<http://www.acquisition.gov/far-overhaul>

| FAR SOURCE | TITLE AND DATE                                                                                                                            |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| 52.203-11  | Certificate and Disclosure Regarding Payments to Influence Certain Federal Transactions (SEP 2024)                                        |
| 52.203-18  | Prohibition on Contracting with Entities that Require Certain Internal Confidentiality Agreements or Statements-Representation (JAN 2017) |
| 52.204-7   | System for Award Management – Registration (DEVIATION) (APR 2026)                                                                         |
| 52.212-1   | Instructions to Offerors—Commercial Products and Commercial Services (DEVIATION) (APR 2026)                                               |
| 52.229-11  | Tax on Certain Foreign Procurements—Notice and Representation (APR 2026)                                                                  |
| 52.240-90  | Security Prohibitions and Exclusions Representations and Certifications (DEVIATION) (APR 2026)                                            |

### 2. Federal Acquisition Regulation (FAR) Provisions Incorporated in Full Text

#### FAR 52.212-2 Evaluation—Commercial Products and Commercial Services (DEVIATION)(RFO APR 2026)

(a) Evaluation factors. The Government will award a contract resulting from this solicitation to the responsible Offeror whose offer conforming to the solicitation will be most advantageous to the Government, price and other factors considered using the tradeoff process. The following factors, listed in descending order of importance, will be used to evaluate offers:

- Factor 1: Technical
  - Sub-Factor 1: Technical Approach
  - Sub-Factor 2: Management Approach
  - Sub-Factor 3: Similar Experience
- Factor 2: Price
- Factor 3: Past Performance

Evaluation factors other than price when combined are significantly more important than price.

(b) *Options (if applicable)*. The Government will evaluate offers for award purposes by adding the total price for all options to the total price for the basic requirement. The Government may determine that an

offer is unacceptable if the option prices are significantly unbalanced. The evaluation of options does not obligate the Government to exercise the option(s).

(c) *Notice of award.* A written notice of award or acceptance of an offer furnished to the successful Offeror within the time for acceptance specified in the offer, shall result in a binding contract without further action by either party. Before the offer's specified expiration time, the Government may accept an offer (or part of an offer), whether or not there are negotiations after its receipt, unless a written notice of withdrawal is received before award.

(End of provision)

#### **FAR 52.216-1 TYPE OF CONTRACT (APR 1984)**

The Government contemplates award of a Firm Fixed Price Contract for this solicitation.

(End of provision)

### **3. Health and Human Services Acquisition Regulation (HHSAR) Clauses Incorporated in Full Text**

#### **HHSAR 352.239-78 Information and Communication Technology Accessibility Notice (DEVIATION)(FEB 2024)**

(a) Any Offeror responding to this solicitation must comply with established HHS Information and Communication Technology (ICT) accessibility standards. Information about Section 508 is available at <https://www.hhs.gov/web/section-508/index.html>.

(b) The Section 508 accessibility standards applicable to this solicitation are stated in the clause at 352.239-79 Information and Communication Technology Accessibility. In order to facilitate the Government's determination whether proposed ICT supplies, products, platforms, information, and documentation meet applicable Section 508 accessibility standards, Offerors must submit an appropriate HHS Section 508 Accessibility Conformance Checklist (see <https://www.hhs.gov/web/section-508/accessibility-checklists/index.html>) or an Accessibility Conformance Report (ACR) (based on the Voluntary Product Accessibility Template (VPAT) see <https://www.itic.org/policy/accessibility/vpat>), in accordance with the completion instructions. The purpose of the checklists and conformance reports are to assist HHS acquisition and program officials in determining whether proposed ICT supplies, products, platforms, information, and documentation conform to applicable Section 508 accessibility standards. Checklists and ACRs evaluate—in detail—whether the ICT conforms to specific Section 508 accessibility standards and identifies remediation efforts needed to address conformance issues.

(c) If an Offeror claims its supplies or services meet applicable Section 508 accessibility standards, and it is later determined by the Government, *i.e.*, after award of a contract or order, that supplies, products, platforms, information, documentation, or services support delivered do not conform to the described accessibility standards, remediation of the supplies, products, platforms, information, documentation, or services support to the level of conformance specified in the contract will be the responsibility of the Contractor at its expense.

(d) In order to facilitate the Government's determination whether proposed ICT supplies meet applicable Section 508 accessibility standards, Offerors must submit an Accessibility Conformance Report, in accordance with its completion instructions and tailored to the requirements in the solicitation. The



purpose of the Report is to assist HHS acquisition and program officials in determining whether proposed ICT supplies conform to applicable Section 508 accessibility standards. The template allows Offerors or developers to self-evaluate their supplies and document, in detail, whether they conform to a specific Section 508 accessibility standard, and any underway remediation efforts addressing conformance issues. Instructions for preparing the HHS Section 508 Evaluation Template are available at <https://Section508.gov/>.

(e) In order to facilitate the Government's determination whether proposed ICT services meet applicable Section 508 accessibility standards, Offerors must provide enough information to assist the Government in determining that the ICT services conform to Section 508 accessibility standards, including any underway remediation efforts addressing conformance issues.

(f) Respondents to this solicitation must identify any inability to conform to Section 508 requirements. If an Offeror claims its supplies or services meet applicable Section 508 accessibility standards, and it is later determined by the Government, i.e., after award of a contract or order, that supplies or services delivered do not conform to the described accessibility standards, remediation of the supplies or services to the level of conformance specified in the contract will be the responsibility of the Contractor at its expense.

(g) Items delivered as electronic content must be accessible to HHS acceptance criteria. Checklist for various formats are available at <http://508.hhs.gov/>. Materials, other than items incidental to contract management, that are final items for delivery should be accompanied by the appropriate checklist, except upon approval of the Contracting Officer or Contracting Officer's Representative.

(End of provision)

#### **4. CDC Local Terms Solicitations Terms and Conditions**

##### **CDCL.03 – Disclosure of Artificial Intelligence Use in Contract Performance (MAY 2026)**

Offerors must affirmatively identify in their proposal whether or not Artificial Intelligence (AI), including Generative AI, is planned, expected, or may be used in the performance of this contract. If planned or potential AI use is identified, offerors must submit an AI Compliance and Risk Management Plan in accordance with **CDCH.10** using the template provided.

##### **CDCL.09 Contractor Performance Assessment Reporting System (CPARS) Requirements (JAN 2026)**

In accordance with FAR 42.11, Centers for Disease Control and Prevention (CDC) will review and evaluate contract performance. FAR 42.1101 and 42.1102 requires agencies to prepare evaluations of contractor performance and submit them to the Contractor Performance Assessment Reporting System (CPARS). CDC utilizes this web-based system to prepare and report contractor performance evaluations. All information contained in these assessments may be used by the Government, within the limitations of FAR 42.11, for future source selections in accordance with FAR 15.104 where past performance is an evaluation factor.

The CPARS system requires a contractor representative to be assigned so that the contractor has appropriate input into the performance evaluation process. The CPARS contractor representative will be given access to CPARS and will be given the opportunity to concur or not-concur with performance

evaluations before the evaluations are complete. The CPARS contractor representative will also have the opportunity to add comments to performance evaluations.

The assessment is not subject to the Disputes clause of the contract, nor is it subject to appeal beyond the review and comment procedures described in the guides on the CPARS website. Refer to: [www.cpars.gov](http://www.cpars.gov) for details and additional information related to CPARS, CPARS user access, how contract performance assessments are conducted, and how contractors participate. Access and training for all persons responsible for the preparation and review of performance assessments is also available at the CPARS website.

The contractor must provide the CDC contracting office with the name, e-mail address, and phone number of their designated CPARS representative who will be responsible for logging into CPARS and reviewing and commenting on performance evaluations. The contractor must maintain a current representative to serve as the contractor representative in CPARS. It is the contractor's responsibility to notify the CDC contracting office, in writing (letter or email), when their CPARS representative information needs to be changed or updated. Failure to maintain current CPARS contractor representative information will result in the loss of an opportunity to review and comment on performance evaluations.

Provide the current CPARS representative information below.

---

PRINT OR TYPE NAME

---

EMAIL ADDRESS AND PHONE NUMBER

### **CDCL.10 Data Management Plan (Instructions) (NOV 2018)**

CDC requires awardees of contracts that involve the collection or generation of public health data with federal funds to develop, submit, and comply with the requirement of a Data Management Plan (DMP) for each collection or generation of public health data undertaken. Consistent with the terms of and activities expected under the statement of work, the offeror shall develop and submit a DMP as part of its proposal in response to this solicitation, and if awarded a contract, update the DMP throughout the life cycle of the public health data collected or generated during the performance period. The DMP shall describe, to the extent appropriate, the data to be collected or generated; plans for making the data accessible that state what the data represent and potential limitations for use, provisions for the protection of privacy, confidentiality, security, intellectual property, or other rights (where these protections preclude making data accessible, justification must be provided); and plans for archiving and long-term preservation of the data. Costs, if any, associated with developing and implementing a DMP, including costs of sharing, archiving and long-term preservation, are allowable costs and shall therefore be reflected in an offeror's Business Proposal. A DMP must be developed in accordance with the below guidelines.

A proposal received without a DMP will be deemed "Unacceptable".

A DMP for each collection and/or generation of public health data should include the following information:

- A description of the public health data to be collected or generated in the contract period of performance;
- Standards to be used for the collected or generated public health data;

- Mechanisms for or limitations to providing access to and sharing of the data (include a description of provisions for the protection of privacy, confidentiality, security, intellectual property, or other rights) or justification for why data cannot be made accessible This section should address access to identifiable and de-identified data (see below for additional information about access);
- Statement of the use of data standards that ensure all released data have appropriate documentation that describes the method of collection, what the data represent, and potential limitations for use; and;
- Plans for archiving and long-term preservation of the data, or explanation of why long-term preservation and access are not justified. This section should address archiving and preservation of identifiable and de-identified data (see *Public Access to CDC Funded Digital Public Health Data*) for additional information regarding archiving).

### **Examples of Data Management Plan Templates and Tools:**

University of California: <https://www.cdlib.org/services/uc3/dmpt.html>

### **CDCM.01 Technical Strength More Important than Cost/Price (JUL 2017)**

Offerors are advised that all evaluation factors other than cost or price, when combined are significantly more important than cost or price. If Technical Proposals are judged to be essentially equal, cost or price will become the determining factor. Award will be made to the responsible offeror submitting the proposal (Technical and Price) determined to be the most advantageous and present the best value to the Government as evaluated under the criteria described in this solicitation.

### **CDCM.03 Evaluation of the Data Management Plan (DMP) (Nov 2018)**

The Data Management Plan submitted as a part of the offeror's proposal will be evaluated during the pre-award process for quality and completeness and will potentially require later revision as the DMP will be updated during the contract period of performance. The DMP will be rated on a "Pass/Fail" basis considering the clearness, appropriateness, and inclusiveness of the elements described under *Data Management Plan (Instructions)*. The Government's evaluation will consider the level or magnitude of the standards to be used for the collected or generated public health data as well as the types of mechanisms for or limitations in providing access to and sharing of the data. Evaluation will also consider how well the DMP clearly outlines plans for archiving and long-term preservation of the data.

For statements of work that involve defined projects which include public health data collection or generation of data, proposals submitted without the required DMP will be deemed unacceptable. For contracts where data collection or generation of data activities may later become known and necessary (e.g. via contract modification), DMPs will be required to be submitted for evaluation and acceptance during the period of performance and must be developed in accordance with *Public Access to CDC Digital Public Health Data*.

### **CDCM.04 Evaluation of Artificial Intelligence Compliance and Risk Management Plan (May 2026)**

The Artificial Intelligence (AI) Compliance and Risk Management Plan submitted as a part of the offeror's proposal will be evaluated for quality and completeness. The AI Compliance and Risk Management Plan will be rated on a "Pass/Fail" basis considering the clearness, appropriateness, and inclusiveness of the elements described under **CDCH.10**.

All proposals that contain planned or potential AI use and do not contain an acceptable AI Compliance and Risk Management Plan will be considered non-responsive and ineligible for award.

The AI Compliance and Risk Management Plan may require later revision during contract performance as described in CDCH.10.

## Section F – Instructions to Offerors

### I. General Instructions

- **Proposal Submission and Authorized Signature.** The proposal must be signed by an official authorized to legally bind the Offeror. The Offeror shall submit one complete electronic copy of all proposal documents in MS Office Word, Excel, and/or PDF format via email to H. Dale Bish, Contracting Officer, Centers for Disease Control and Prevention (CDC), Office of Acquisition Services, at [uwo8@cdc.gov](mailto:uwo8@cdc.gov). All questions, requests for clarification, and other inquiries concerning this RFQ shall be submitted exclusively by email to [uwo8@cdc.gov](mailto:uwo8@cdc.gov).
- **Proposal Format and Page Limitations.** These instructions establish the minimum acceptable requirements for the format and content of proposals submitted in response to this RFQ. The Technical Proposal shall not exceed 15 pages. Cover pages, tables of contents, and resumes are excluded from the page limitation.

For purposes of the page limitation, a page shall consist of an 8½-inch by 11-inch sheet with one-inch margins on all four sides. Technical Proposal text shall be presented in Times New Roman, **minimum 10-point font**, single-spaced. Text pages shall use portrait orientation. Alternative formatting may be used for illustrations, charts, and tables when necessary; however, all such materials must remain clear, legible, and readily understandable.

The minimum font sizes are:

- 8-point font for graphs and illustrations; and
- 10-point font for tables and text.
- **Electronic File Size Requirements.** CDC's email server will not accept attachments exceeding 12 megabytes (MB). Offerors shall ensure that individual email attachments do not exceed the applicable server limitation. If the complete proposal exceeds 10 MB, or if embedded graphics or other content cause the file size to approach that threshold, the Offeror shall divide the submission into multiple emails. Each email shall contain attachments that remain within the applicable size limitation.

Each email should clearly identify the solicitation number, Offeror name, proposal volume, and sequence of the submission (e.g., "Email 1 of 3"). The Offeror is responsible for ensuring that all proposal volumes and attachments are successfully transmitted and received by the Government.

- **Page Numbering.** The Offeror shall consecutively number every page of the proposal to facilitate accurate page-count verification. If the Offeror's page numbering creates an ambiguity regarding the applicable page limitation, the Government reserves the right to determine, at its sole discretion, how the pages will be counted. Pages exceeding the applicable page limitation will not be evaluated.
- **Volume 1 – Technical Proposal.** The Technical Proposal shall not contain pricing or other information that identifies the Offeror's proposed price.

The Technical Proposal shall, however, include sufficient resource information to permit the Government to evaluate the Offeror's understanding of and approach to the requirements. Such information may include, as applicable, proposed labor categories, labor hours, materials,

subcontractor support, organizational resources, and other non-price resource information necessary to demonstrate the Offeror's capability to perform the work.

- **Volume 2 – Price Proposal.** The Price Proposal has no page limit and shall provide a complete and transparent representation of all resources and costs required to perform the contract requirements.

All numerical amounts shall be actually rounded to the nearest two decimal places, rather than merely displayed as two decimal places.

The Offeror shall submit the pricing information in both Excel and PDF formats. Pricing schedules and charts shall be provided as editable data tables or spreadsheets and shall not consist of images, screenshots, or pictures of data charts.

The Contracting Officer reserves the right to request additional supporting information or data concerning proposed pricing as necessary to evaluate the fairness and reasonableness of the proposed amounts. The Offeror shall provide requested supporting information within the timeframe established by the Contracting Officer.

- **Proposal Preparation Costs.** The Government will not reimburse, compensate, or otherwise pay any costs incurred by an Offeror in preparing, developing, or submitting a proposal in response to this RFQ. All proposal preparation and submission costs shall be borne solely by the Offeror.
- **Authorized Communications.** The Contracting Officer is the only individual authorized to legally obligate the Government or commit public funds in connection with this acquisition. No other Government employee, representative, or official is authorized to make such a commitment on behalf of the Government.

All communications concerning this RFQ, including questions, requests for clarification, and other acquisition-related matters, shall be directed exclusively to the designated Contracting Officer or Contract Specialist through the authorized communication channel identified in this RFQ.

Communications with unauthorized Government personnel or other individuals concerning the substance of this RFQ prior to contract award may result in adverse consequences to the Offeror, including potential jeopardy to the Offeror's eligibility for award.

- **Award Without Negotiations.** The Government intends to evaluate proposals and make award without conducting negotiations or requesting proposal revisions. Accordingly, Offerors shall ensure that their initial proposals are complete, accurate, responsive, and fully compliant with all solicitation requirements. Offerors should not assume that the Government will provide an opportunity to correct omissions, clarify material deficiencies, or revise proposed technical or price information after submission.
- **Submission Deadline and Delivery.** The complete proposal shall be submitted by email to H. Dale Bish at [uwo8@cdc.gov](mailto:uwo8@cdc.gov) no later than the date and time specified on Page 1 of the RFQ.

The Offeror is solely responsible for ensuring timely delivery and successful receipt of the proposal. Submission of an email does not, by itself, establish Government receipt. Offerors should allow sufficient time for email transmission, attachment processing, and any required division of the proposal into multiple emails.

## II. Technical Proposal Contents

The Offeror shall submit a Technical Proposal that demonstrates its understanding of the requirements of the Performance Work Statement (PWS), its proposed technical and management approaches, and its relevant experience. The Technical Volume shall be organized by tab as specified below.

Information submitted in the Technical Proposal shall be sufficiently detailed to permit the Government to evaluate the Offeror's understanding, approach, experience, and ability to successfully perform the requirements. Offerors should provide clear, concise, and specific information addressing each requirement. Merely restating the requirements of the PWS is not sufficient.

| Volume | Title                                                                                                                                                                                                                                                                                                                                                                                                                                                          | Page Limit | Total Copies      |
|--------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|-------------------|
| I      | Technical Proposal:<br>Tab 1: Executive Summary<br><br>Tab 2: Technical Approach<br>Tab 2-1: Technical Plan<br>Tab 2-2: Prototype<br><br>Tab 3: Management Approach<br>Tab 3-1: Management Plan<br>Tab 3-2: Key Personnel Resumes (2 pages per resume) (excluded from page limit)<br><br>Tab 4: Similar Experience<br><br>Tab 5 (excluded from page limit):<br>Data Management Plan (CDCL.10) and AI Compliance and Risk Management Plan (CDCH.10 and CDCL.03) | 15 Pages   | 1 electronic copy |
| II     | Price Proposal:<br>Tab 1: Price Breakdown Worksheet                                                                                                                                                                                                                                                                                                                                                                                                            | Unlimited  | 1 electronic copy |

### Tab 1: Executive Summary

The Offeror may provide an Executive Summary describing its overall approach and highlighting significant aspects of its proposal.

### Tab 2: Technical Approach

#### Tab 2-1: Technical Plan

The Offeror shall provide a detailed Technical Plan addressing each of the following areas:

### **1. Understanding of the Problem, Scope, and Purpose**

The Offeror shall provide a detailed and comprehensive description of:

- Its understanding of the problem to be addressed;
- The scope and purpose of the project;
- The objectives and intended outcomes of the contract;
- The Offeror's understanding of the intent and requirements of the PWS; and
- Potential technical, operational, or other challenges that may be encountered during performance and the Offeror's anticipated approach to addressing those challenges.

### **2. Technical Approach**

The Offeror shall describe its technical approach for complying with each applicable requirement of the PWS. The response shall:

- Demonstrate alignment with the stated goals and objectives;
- Describe the methods, processes, tools, and techniques the Offeror will use to accomplish the required work;
- Explain how the proposed approach will support timely and acceptable performance;
- Identify key activities, dependencies, deliverables, and anticipated outcomes; and
- Include milestone and/or phasing charts that illustrate a logical sequence and timing of proposed activities and events.

### **3. Project Plan and Solutions**

The Offeror shall provide a project plan describing how it will execute the required work. The plan shall:

- Identify the major phases and activities necessary to accomplish the PWS requirements;
- Describe the approach for coordinating and integrating project activities;
- Identify anticipated difficulties, constraints, or challenges associated with performance; and
- Provide specific, practical solutions and approaches for overcoming those difficulties and maintaining successful performance.

The Technical Plan should provide sufficient detail for the Government to understand what the Offeror will do, how it will do it, when it will do it, and how the approach will support successful contract performance.

### **Tab 2-2: Prototype**

The Offeror shall provide a prototype demonstrating its proposed solution and technical approach. The prototype shall be submitted through an accessible electronic link that can be accessed and evaluated by the Government.



The prototype shall demonstrate, to the maximum extent practicable, the Offeror's proposed capabilities and approach relevant to the requirements of the PWS. The Offeror shall provide sufficient information or documentation accompanying the prototype to enable the Government to understand how the prototype relates to the proposed solution.

The prototype shall address the following areas:

1. **Understanding of the Problem and Objectives** – Demonstrate an understanding of the problem, user needs, project objectives, and intended outcomes.
2. **Soundness and Feasibility of the Technical Approach** – Demonstrate that the proposed technical solution is technically sound, practical, and feasible to implement and operate.
3. **Innovation and Originality** – Demonstrate innovative or original features, methods, technologies, or approaches that contribute to the effectiveness of the proposed solution.
4. **Technical Risks and Mitigation Strategies** – Identify significant technical risks associated with the proposed solution and demonstrate how those risks can be mitigated.
5. **Alignment with Performance Requirements** – Demonstrate alignment with the applicable performance requirements and desired outcomes identified in the PWS.
6. **Scalability and Extensibility** – Demonstrate the ability of the proposed design or solution to scale, accommodate future requirements, and/or be extended as project needs evolve.

### **Tab 3: Management Approach**

#### **Tab 3-1 Management Plan**

The Offeror shall provide a Management Plan describing its approach for effectively managing and performing the **contract**. The Management Plan shall address the following:

#### **1. Organizational Structure and Decision-Making**

The Offeror shall describe its proposed organizational structure, including:

- The roles and responsibilities of key organizational elements and personnel;
- The reporting relationships and lines of authority;
- The role and responsibilities of the Program Manager; and
- The Program Manager's decision-making authority in relation to other elements of the Offeror's organization.

The Offeror shall explain how its organizational structure will facilitate effective decision-making, accountability, coordination, and successful **contract** performance.

#### **2. Staffing and Workforce Management**

The Offeror shall describe its approach to rapidly obtaining, assigning, and/or replacing qualified personnel to support existing and new **contract** requirements and changing workload demands.

The response shall address:

- Recruitment and staffing processes;
- Availability of qualified personnel;
- Turnover rate for the past three years in table format;
- Procedures for replacing personnel when necessary;
- Approaches for addressing increases or decreases in workload;
- Continuity of operations and knowledge transfer; and
- Methods for minimizing the impact of personnel turnover on performance.

### 3. Performance Monitoring and Metrics

The Offeror shall identify the metrics and performance parameters it proposes to use to monitor contract performance. The response shall explain:

- What performance measures will be tracked;
- How and how frequently performance will be monitored;
- How performance information will be reported and communicated;
- How deviations from expected performance will be identified; and
- What corrective actions will be taken when performance does not meet established expectations.

### 4. Contract Management, Quality, Risk, and Communication

The Offeror shall describe its methodology for managing the contract, including:

- Management processes and tools;
- Work planning and tracking;
- Coordination and collaboration processes;
- Quality assurance and quality control methods;
- Methods for ensuring timely delivery of quality products and services;
- Risk identification, assessment, monitoring, and mitigation;
- Issue escalation and resolution; and
- Internal and Government communication processes.

The Offeror shall explain how these management practices will be integrated to support effective, transparent, and successful contract performance.

### 5. Subcontractor Management

If subcontractors are proposed, the Offeror shall:

- Identify each portion of the **contract** that will be performed by a subcontractor;
- Identify the specific duties and labor categories that will be performed by each proposed subcontractor;
- Describe the Offeror's approach to managing and integrating subcontractor performance into the overall **contract**; and
- Provide a written copy of the proposed draft Subcontracting Agreement.

If no subcontractors are proposed, the Offeror shall clearly state that no subcontracting opportunities exist.

### **Tab 3-2: Key Personnel Resumes**

The Offeror shall provide resumes for all proposed Key Personnel identified by the Offeror.

Each resume shall clearly demonstrate the individual's qualifications, experience, expertise, and training relevant to the requirements of the PWS. Resumes should specifically identify:

- Length and variety of relevant professional experience;
- Experience performing tasks similar to those required under the project;
- Relevant technical and professional expertise;
- Relevant education, certifications, and training; and
- Hands-on experience directly applicable to the proposed work.

The resumes shall clearly demonstrate prior hands-on experience in one or more applicable areas, including healthcare informatics, public health surveillance systems, healthcare data management, or healthcare-related information technology, as relevant to the project tasks.

Offerors should identify the specific projects, responsibilities, technologies, systems, and accomplishments that demonstrate each Key Personnel's relevance to the proposed work.

### **Tab 4: Similar Experience**

The Offeror shall provide information demonstrating its experience performing projects that are similar in scope, size, complexity, technical requirements, healthcare IT domain, stakeholder environment, and regulatory environment to the requirements of the solicitation.

The Offeror shall address the following:

#### **1. Similar Scope, Size, Complexity, and Healthcare IT Expertise**

The Offeror shall describe relevant projects that demonstrate:

- Experience performing work of similar scope, size, and complexity;
- Healthcare IT domain expertise relevant to the solicitation;

- Experience performing comparable technical and operational requirements; and
- Successful application of relevant knowledge, capabilities, tools, and processes.

The Offeror shall provide all information required by the solicitation for each relevant experience example.

## **2. Application of Healthcare Domain Expertise**

The Offeror shall demonstrate how its healthcare domain expertise has been applied to successfully perform comparable projects. The response shall address, as applicable:

- Healthcare workflows and operational processes;
- Healthcare data and information systems;
- Risk identification and mitigation;
- Stakeholder identification, coordination, and engagement;
- User needs and requirements management; and
- Other healthcare-specific considerations relevant to the requirements of the solicitation.

## **3. Documented Evidence of Similar Experience**

The Offeror shall provide documented evidence supporting its claimed experience. Examples of supporting evidence may include:

- Project summaries;
- Contract or task order descriptions;
- Performance references;
- Customer information;
- Deliverables or other representative artifacts;
- Performance metrics or outcomes; and
- Other documentation demonstrating successful performance.

The Offeror should clearly explain how each cited experience example is relevant to the requirements of this solicitation, including similarities in scale, stakeholders, technical environment, healthcare domain, and regulatory requirements.

For each experience example, the Offeror should identify the specific aspects of prior performance that demonstrate its ability to successfully perform the requirements of this solicitation. Simply identifying a prior contract or project without explaining its relevance will not adequately demonstrate similar experience.

### **III. Price Proposal Contents**

The Price Proposal shall provide supporting documentation to back-up the pricing proposed. The back-up documentation shall demonstrate the correlation between the proposed technical requirements in the Performance Work Statement (PWS) and the pricing submitted. The Price Proposal shall include itemization for all proposed pricing including direct labor, materials, supplies, subcontracting, and other direct costs. Offerors shall provide labor categories, labor hours, labor rates, materials, supplies, and any other direct costs associated with each CLIN. A response that includes only completing an Excel spreadsheet with bottom line / final summary numbers and no supporting details shall be determined to be non-responsive to the solicitation.

Submit all (if any) assumptions, conditions, or exceptions with any of the terms and conditions included in this solicitation. If not noted in this section of the proposal, it will be assumed that the Offeror proposes no assumptions, conditions, or exceptions for award and agrees to comply with all of the terms and conditions as set forth herein. It is not the responsibility of the Government to seek out and identify assumptions, conditions, or exceptions included in the Technical Proposal, Price Proposal, or any other response documents submitted.

To increase transparency, each IT supply (licenses, cloud services, and hardware) or service must be a separately priced line item in the Price Proposal. At the time of award, separate CLINs shall be used to separate these costs.

At a minimum, the Price Proposal shall identify, as applicable:

- Labor categories and proposed labor hours;
- Labor rate tables;
- Materials;
- Equipment;
- Subcontracts;
- Other Direct Costs (ODCs);
- Incidental costs;
- Government-Furnished Equipment (GFE);
- Government-Furnished Information (GFI); and
- Any other resources or costs necessary to fulfill the requirements of the contract.

## **Section G – Basis of Award and Evaluation Factors**

### **1. Basis of Award – Best Value Tradeoff Source Selection**

This contract shall be awarded using a best value tradeoff source selection process. Award will be made to the responsible Offeror whose proposal is determined, in accordance with the evaluation criteria, to represent the best overall value and be most advantageous to the Government.

The Government will evaluate proposals based on the stated non-price evaluation factors and price, considering the relative strengths, weaknesses, risks, and overall value presented by each Offeror. The Government will assess the extent to which each proposal demonstrates a clear understanding of the requirements, a sound and feasible technical approach, relevant experience, qualified resources, effective management, and a reasonable likelihood of successful contract performance.

Trade-offs between price and non-price factors are expressly permitted. The Government may determine that a proposal offering superior technical capability, reduced performance risk, stronger relevant experience, greater management effectiveness, or other meaningful advantages provides greater overall value than a lower-priced proposal. Accordingly, the Government expressly reserves the right to award to an Offeror other than the Offeror submitting the lowest-priced proposal. However, the Government will not pay a significantly higher overall price solely to obtain minor, incremental, or otherwise marginal improvements in performance that do not provide a commensurate benefit to the Government.

The Government's source selection determination will be based solely on the information contained in the submitted proposals and the evaluation criteria established in this solicitation, subject to any additional information the Government is authorized to consider under applicable acquisition regulations. Offerors shall therefore ensure that the proposals clearly identify and substantiate the specific benefits, discriminators, capabilities, and advantages they are offering.

The Government reserves the right to make award based on the initial proposals without conducting negotiations or requesting proposal revisions. Offerors should therefore submit the most advantageous Technical and Price Proposals initially and should not assume that an opportunity will be provided to correct deficiencies, enhance strengths, or revise pricing after submission.

### **2. Technical Proposal Evaluation**

#### **A. TECHNICAL AREA**

##### **i. Tab 1: Executive Summary**

For evaluation purposes the Executive Summary is not considered. Information the Offeror wants evaluated from the Executive Summary must be included in the appropriate volume.

##### **A1: Technical Approach Factor**

This Factor evaluates the Offeror's ability to address all aspects of their technical approach to meet and deliver on Performance Work Statement (PWS) requirements as further described in the sub-factors listed below.

##### **ii. Tab 2-1: Technical Plan**

The Technical Plan shall be evaluated for adequacy in how well it addresses:

- 1) A detailed and comprehensive statement of the problem, scope, and purpose of the project to demonstrate complete understanding of the intent and requirements of the contract and potential problems that may be encountered.

2) A technical approach to comply with each of the requirements specified in the PWS; that is consistent with the stated goals and objectives; ensures the achievement of timely and acceptable performance; and details a milestone and/or phasing charts to illustrate a logical sequence of proposed events.

3) A project plan that provides the approach and includes solutions for overcoming difficulties involved with performing the work requirements.

ii. Tab 2-2: Prototype (*Submitted via an accessible link*)

The Prototype will be evaluated based on the following areas:

- 1) Understanding of the problem and objectives
- 2) Soundness and feasibility of the technical approach
- 3) Innovation and originality
- 4) Technical risks and mitigation strategies
- 5) Alignment with stated performance requirements
- 6) Scalability or extensibility of the design

A2: Management Approach Factor

iv. Tab 3-1: Management Plan

The Management Plan shall be evaluated for adequacy in how well it addresses:

- 1) Its organizational structure and how it proposes to manage this **contract** including the decision-making authority of the Program Manager as related to other elements of the organization.
- 2) A description of the Offeror's approach to rapidly obtain and/or replace qualified staffing resources to support existing and new **contract** work and to meet changing workload requirements, including a table showing employee turnover rates for each of the past three years.
- 3) The proposed metrics and performance parameters for monitoring performance and how clearly the metrics will be monitored, and corrective action taken, if appropriate.
- 4) The methodology for managing the **contract**; any management tools it will use; how it will ensure quality products are delivered; how it will mitigate risk; and how it will communicate.
- 5) If subcontractors are proposed, the identification of any portions of the **contract** that will be performed by subcontractors, inclusion of the specific duties and labor categories that will be performed by the subcontractor, and a written copy of the draft Subcontracting Agreement.

v. Tab 3-2: Key Personnel Resumes

The Key Personnel resumes shall be evaluated for adequacy in how well they address:

The backgrounds of the personnel to reflect the length and variety of experience and expertise in tasks similar to the tasks required by this project and any relevant training (e.g., healthcare data management, healthcare informatics or healthcare related IT experience). Resumes must clearly demonstrate prior hands-on experience with healthcare informatics, public health surveillance systems, or healthcare data management relevant to project tasks.

A3: Similar Experience Factor

vi. Tab 4: Similar Experience

Similar Experience shall be evaluated for adequacy in how well it addresses:

- 1) Demonstrates the Offeror's experience in performing projects of similar scope and with healthcare IT domain expertise, size and complexity to the requirements described in the solicitation and contains all required content.
- 2) Demonstrate the Offerors experience in how its healthcare domain expertise will be applied to meeting the solicitation requirements, including workflows, risk mitigation, and stakeholder engagement.

3) Demonstrate the Offerors experience with documented evidence (e.g., project summaries, performance references, artifacts) of experience in healthcare IT or healthcare data systems of similar scale, stakeholders, and regulatory environment.

A4: The Data Management Plan shall be evaluated in accordance with CDCM.03 and the Artificial Intelligence Compliance and Risk Management Plan shall be evaluated in accordance with CDCM.04.

### **3. Price Proposal Evaluation**

The Price Proposal will be evaluated for accuracy, completeness, internal consistency, and overall price reasonableness. The Offeror bears the responsibility for demonstrating that its proposed price is fair, reasonable, and adequately supported. Proposed pricing shall establish a logical relationship among all cost and price elements, the proposed technical approach, level of effort, labor categories and hours, resources, deliverables, and other requirements. The Government will assess whether the Price Proposal reflects a clear understanding of the requirement and is consistent with the Offeror's Technical Proposal.

The Government may evaluate the proposed price for completeness and consistency and may consider any significant omissions, unsupported assumptions, mathematical discrepancies, or inconsistencies between the Technical and Price Proposals. The Government may request additional supporting information, as permitted by the solicitation and applicable regulations, to determine the basis and reasonableness of proposed prices.

To determine fair and reasonable pricing, the Government may use any appropriate price analysis techniques and procedures, including comparison of proposed prices received, historical prices paid by the Government or other customers, parametric estimating methods, competitive or published price lists, the Independent Government Cost Estimate (IGCE), market research for the same or similar requirements, and comparison of individual cost elements such as labor, materials, travel, and other direct costs.

### **4. Past Performance Evaluation**

The Government shall obtain past performance information on the Offeror. The past performance information can be obtained from a variety of sources including, but not limited to, information reported in CPARS, feedback obtained from points of contact on existing CDC contracts, and feedback obtained from points of contact on other federal or commercial contracts.

Each Offeror shall be evaluated on its past performance under current and prior contracts. By past performance, the Government means the Offeror's record of conforming to specifications and to standards of good workmanship, the Offeror's record of forecasting and controlling costs, the Offeror's adherence to contract schedules and terms, including the administrative aspects of performance, the Offeror's reputation for reasonable and cooperative behavior and commitment to customer satisfaction, and generally, the Offeror's business-like concern for the interest of the customer and the degree of quality of deliverables and performance. If CPARS is used, CPARS standard rating areas include quality, schedule, cost, management, small business, and regulatory compliance.

Each Offeror shall be evaluated as positive, negative, or neutral on its past performance under current and prior contracts. An Offeror without a record of past performance or for whom past performance is not available shall be evaluated as neutral.